AUREON FINANCIAL SYSTEMS
Security Operations Centre

VULNERABILITY MANAGEMENT
& SECURITY RISK ANALYTICS REPORT

Report Reference:	AFS-SOC-VULN-2026-001
Classification:	INTERNAL USE ONLY
Assessment Period:	20 – 26 February 2026
Prepared By:	SOC Analyst – Emmanuel Ateji
Organisation:	Aureon Financial Systems (AFS)
Report Date:	26 February 2026
Report Version:	Final

TARGET 1	TARGET 2
Metasploitable 2	**VulnWeb PHP App**
10.0.2.4 | Ubuntu 8.04 (EOL)	testphp.vulnweb.com | 44.228.249.3:80

Table of Contents

1. Executive Summary
2. Introduction
3. Project Objectives
4. Scope of Assessment
5. Methodology
6. Assessment Tools & Environment
7. Target 1: Metasploitable 2 (10.0.2.4)
   7.1 Target Profile
   7.2 Risk Summary
   7.3 Vulnerability Index (101 Findings)
   7.4 Detailed Findings
   7.5 Remediation Roadmap: Metasploitable 2
8. Target 2: VulnWeb Application (testphp.vulnweb.com)
   8.1 Target Profile
   8.2 Risk Summary
   8.3 Vulnerability Index (18 Findings)
   8.4 Detailed Findings
   8.5 Remediation Roadmap: VulnWeb Application
9. Overall Remediation Roadmap
10. Conclusion
11. Appendix A: Glossary of Terms
12. Appendix B: Raw Scan Reports

1. Executive Summary

This report presents the findings of a structured vulnerability assessment conducted by the Security Operations Centre (SOC) of Aureon Financial Systems (AFS) as part of the organisation's Vulnerability Management & Security Risk Analytics project. The assessment was carried out between 20 and 26 February 2026 against two target systems: Metasploitable 2 (10.0.2.4) and the web application hosted at testphp.vulnweb.com (44.228.249.3:80).

The assessment employed seven scan configurations across five industry-standard tools: Tenable Nessus, Qualys VMDR, Greenbone OpenVAS, OWASP ZAP, and Nikto. Nessus and Qualys were each used to perform both a basic unauthenticated scan and an advanced credentialed scan using SSH details on the 10.0.2.4 target, providing substantially deeper system-level visibility than unauthenticated scanning alone.

A total of 119 unique vulnerabilities were identified across both targets: 101 on Metasploitable 2 and 18 on the VulnWeb application. Both targets were assessed as critically vulnerable and require immediate action.

1.1 Aggregated Risk Distribution

Severity	Metasploitable 2	VulnWeb App	Combined Total
Critical	19	2	**21**
High	33	3	**36**
Medium	34	4	**38**
Low	9	4	**13**
Informational	6	5	**11**
TOTAL	101	18	**119**

Both targets are in a critically vulnerable state. Metasploitable 2 hosts four confirmed active backdoors granting immediate root-level access with zero authentication, including a previously undocumented ProFTPD 1.3.3c backdoor on port 2121/tcp and a second exposed Apache Tomcat Manager on port 8180. A total of 101 vulnerabilities were confirmed on Metasploitable 2 alone, including 6 distinct Samba RCE paths. The VulnWeb application exposes SQL injection across six endpoints and transmits all credentials in cleartext over HTTP. Immediate isolation of 10.0.2.4 and emergency patching of the VulnWeb PHP runtime are the first required actions.

2. Introduction

2.1 Organisational Context

Aureon Financial Systems (AFS) is a mid-sized digital financial services provider headquartered in Austin, Texas. Founded in 2014, AFS operates a hybrid cloud infrastructure supporting digital payment processing, online banking dashboards, merchant analytics, and API integrations for over 500,000 active business users. The organisation processes billions of dollars in annual transactions, making the security of its systems a matter of direct regulatory and commercial consequence.

The financial services sector is among the most heavily targeted industries for cyberattacks. Threat actors routinely exploit known but unpatched vulnerabilities rather than developing novel zero-day exploits, as the cost-to-exploit ratio of known vulnerabilities remains extremely favourable to attackers. The consequences of a breach at AFS, including regulatory penalties, reputational damage, and direct financial loss, demand a proactive, intelligence-driven approach to vulnerability management.

2.2 Background and Rationale

This vulnerability assessment was commissioned as part of the AFS Vulnerability Management & Security Risk Analytics project, a strategic initiative to transition the organisation from a reactive security posture to a structured, risk-based framework. As AFS expands its digital platform and onboards new third-party integrations, the attack surface has grown correspondingly. Legacy Linux-based servers, rapid feature releases, and inherited technical debt have created an environment where undetected vulnerabilities present escalating risk.

The assessment evaluated two representative target systems: an intentionally vulnerable Linux host (Metasploitable 2) standing in for AFS legacy server infrastructure, and a publicly accessible web application (testphp.vulnweb.com) representing a customer-facing PHP-based service.

2.3 Regulatory and Compliance Context

AFS operates under obligations imposed by multiple regulatory frameworks:

- PCI-DSS: Mandates vulnerability management programmes, secure transmission of cardholder data, and regular scanning and patching cycles. Multiple findings in this report constitute likely PCI-DSS violations.
- GDPR: Requires appropriate technical and organisational measures to protect personal data, including EU-resident business users.
- SOX: Imposes requirements on IT controls supporting financial reporting integrity.
- NIST CSF: Provides a framework for identifying, protecting, detecting, responding to, and recovering from cybersecurity events.

3. Project Objectives

The vulnerability assessment was conducted in alignment with the following objectives drawn from the AFS Vulnerability Management & Security Risk Analytics project framework:

1. Identify Vulnerabilities Proactively: Enumerate all exploitable security weaknesses across targeted systems through credentialed and unauthenticated scanning, and web application testing.
2. Prioritise Risks Intelligently: Rank all identified vulnerabilities using CVSS scoring, EPSS exploitability metrics, and business impact considerations to guide remediation sequencing.
3. Improve Remediation Time: Provide actionable, prioritised remediation guidance to reduce Mean Time to Remediate (MTTR) for critical and high findings.
4. Enhance Reporting and Visibility: Deliver executive-ready consolidated findings that translate technical vulnerability data into business risk language.
5. Strengthen Security Governance: Align findings and remediation recommendations with PCI-DSS, GDPR, SOX, and NIST CSF compliance frameworks.
6. Validate Credentialed vs. Unauthenticated Scanning: Demonstrate the material difference in finding depth between basic and advanced SSH-credentialed scans, supporting the business case for credentialed scanning in production environments.

4. Scope of Assessment

4.1 In-Scope Targets

Target	Identifier	Type	Notes
Metasploitable 2	10.0.2.4	Linux Host	Ubuntu 8.04 EOL. Basic + advanced SSH-credentialed scans (Nessus and Qualys).
VulnWeb PHP App	testphp.vulnweb.com (44.228.249.3:80)	Web Application	PHP 5.6.40 web app on port 80. Web application scans via ZAP, Nessus, OpenVAS, Nikto.

4.2 In-Scope Activities

- Asset identification, OS and service fingerprinting
- Basic unauthenticated network vulnerability scanning (Metasploitable 2)
- Advanced credentialed scanning using SSH credentials (Metasploitable 2, Nessus and Qualys)
- Web application active scanning and testing (both targets)
- CVE identification, CVSS scoring, and EPSS rating where available
- Cross-tool finding correlation, deduplication, and risk-based prioritisation

4.3 Out-of-Scope Activities

- Full SOC implementation, incident response redesign, network infrastructure overhaul
- Manual penetration testing beyond automated scanning scope
- Physical security assessment or social engineering simulation

5. Methodology

The assessment followed a structured, multi-phase methodology aligned with NIST SP 800-115 and the OWASP Testing Guide v4.2.

Phase 1: Reconnaissance and Asset Identification

Network discovery, port enumeration, OS and application version fingerprinting on both targets to establish the attack surface baseline prior to vulnerability scanning.

Phase 2: Unauthenticated (Basic) Vulnerability Scanning

Tenable Nessus and Qualys VMDR were first deployed in unauthenticated mode against Metasploitable 2, simulating an external attacker with no privileged access. Web application scans were initiated against both targets using OWASP ZAP, Nikto, and Greenbone OpenVAS.

Phase 3: Advanced Credentialed Scanning (SSH)

Following basic scans, both Nessus and Qualys were configured with SSH credentials for the Metasploitable 2 host and re-scanned in credentialed mode. This provided authenticated access to the local filesystem and package management system, detecting locally installed vulnerable packages, kernel-level vulnerabilities, configuration file weaknesses, and missing patches invisible to unauthenticated scanners. The credentialed scan revealed 383+ CVEs via Nessus's authenticated plugin set, substantially beyond what unauthenticated scanning detected.

Phase 4: Web Application Testing

OWASP ZAP v2.17.0 was run in active scan mode against both targets. Nikto provided complementary web server scanning. Greenbone OpenVAS provided additional web application coverage. Active scanning deployed targeted attack payloads to discover injection vulnerabilities, authentication flaws, and access control weaknesses.

Phase 5: Finding Analysis and Risk Scoring

All raw scan outputs were reviewed, correlated across tools, and deduplicated. Each finding was assigned a CVSS v3.0 base score (CVSS v2.0 where noted), EPSS score where available, business impact classification, and remediation priority ranking based on combined severity, exploitability, and business impact.

Phase 6: Reporting

Findings were consolidated into this report structured for both SOC analyst (technical detail sections) and senior leadership (executive summary and remediation roadmap) consumption.

6. Assessment Tools & Environment

Tool	Version	Target	Scan Type
Tenable Nessus	Latest	10.0.2.4	Basic Unauthenticated Scan
Tenable Nessus	Latest	10.0.2.4	Advanced Credentialed Scan (SSH)
Qualys VMDR	Latest	10.0.2.4	Basic Unauthenticated Scan
Qualys VMDR	Latest	10.0.2.4	Advanced Credentialed Scan (SSH)
Greenbone OpenVAS	Latest	10.0.2.4	Network Vulnerability Scan
OWASP ZAP	v2.17.0	10.0.2.4	Active Web Application Scan
Nikto	v2.5.0	10.0.2.4	Web Server Scan
OWASP ZAP	v2.17.0	testphp.vulnweb.com	Active Web Application Scan
Tenable Nessus	Latest	testphp.vulnweb.com	Web Application Scan (×2)
Greenbone OpenVAS	Latest	testphp.vulnweb.com	Web Application Scan
Nikto	v2.5.0	testphp.vulnweb.com	Web Server Scan

Credentialed vs. Unauthenticated Scanning: Key Insight

The SSH-credentialed scans on Metasploitable 2 enabled detection of vulnerabilities invisible to network scanning: the Debian weak PRNG (CVE-2008-0166) detectable only via authenticated key inspection, the full scope of EOL package exposure generating 383+ CVEs via Nessus's authenticated plugin set, SSH sshd_config algorithm weaknesses, and installed package version data for all system components. This demonstrates that unauthenticated scanning alone produces a materially incomplete picture of risk. SOC recommends SSH-credentialed scanning as mandatory for all future production server assessments.

7. Target 1: Metasploitable 2 (10.0.2.4)

7.1 Target Profile

Target Host:	10.0.2.4
Operating System:	Ubuntu 8.04 (Hardy Heron), EOL May 2013
System Type:	Intentionally Vulnerable Linux Virtual Machine
Web Applications:	DVWA, Mutillidae, TWiki, phpMyAdmin, various
Tools Used:	Tenable Nessus (×2), Qualys VMDR (×2), Greenbone OpenVAS, OWASP ZAP, Nikto
Scan Types:	Basic Unauthenticated + Advanced Credentialed (SSH) on Nessus and Qualys
Assessment Period:	20 – 26 February 2026
Overall Rating:	CRITICAL - ACTIVELY COMPROMISED

Metasploitable 2 hosts four confirmed active backdoors providing immediate root access with zero authentication: Ingreslock (VULN-01), vsftpd 2.3.4 (VULN-02), UnrealIRCd (VULN-03), and ProFTPD 1.3.3c (VULN-57). A second exposed Apache Tomcat Manager on port 8180 (VULN-58) provides an additional one-step RCE path. The end-of-life Ubuntu 8.04 OS is the root cause of 383+ unpatched CVEs across every installed service and package. The host must be treated as fully compromised from the outset and isolated from all networks without delay.

7.2 Risk Summary

Severity	Count	Description
Critical	19	Immediate exploitation likely. Full system or data compromise.
High	33	Confirmed exploitable with significant direct impact.
Medium	34	Exploitable under realistic conditions or via attack chains.
Low	9	Minor direct impact; provides useful information to attackers.
Informational	6	Attack surface items requiring manual review.
TOTAL FINDINGS	**101**	19 Critical | 33 High | 34 Medium | 9 Low | 6 Informational

7.3 Vulnerability Index

All 101 findings listed in priority order:

ID	Vulnerability	Severity	CVSS	Detected By
VULN-01	Bind Shell Backdoor — Unauthenticated Root Shell (Port 1524/tcp)	**Critical**	10.0	Greenbone OpenVAS (QoD 99%)
VULN-02	vsftpd 2.3.4 Compromised Package Backdoor (Port 6200/tcp)	**Critical**	9.8	Greenbone OpenVAS (QoD 99%)
VULN-03	UnrealIRCd 3.2.8.1 Backdoor — RCE (CVE-2010-2075) and Authentication Spoofing (CVE-2016-7144)	**Critical**	10.0	Nessus (Plugin 46882, EPSS 0.8581)

VULN-04	Shellshock — Bash Remote Code Execution (CVE-2014-6271 / CVE-2014-7169)	**Critical**	9.8	Nessus SSH scan (Plugin 77823, VPR 9.6, EPSS 0.9422)
VULN-05	Apache Tomcat Ghostcat — AJP Connector Request Injection (CVE-2020-1938)	**Critical**	9.8	Nessus (Plugin 134862, VPR 8.9, EPSS 0.9447)
VULN-06	VNC Server — Default Password 'password' (Port 5900/tcp)	**Critical**	10.0	Nessus (Plugin 61708)
VULN-07	PHP CGI Remote Code Execution (CVE-2012-1823)	**Critical**	9.8	Greenbone OpenVAS (QoD 95%, CISA KEV — phpinfo() execution confirmed)
VULN-08	Distributed Ruby (dRuby/DRb) — Unauthenticated Remote Code Execution (Port 8787/tcp)	**Critical**	10.0	Greenbone OpenVAS (QoD 99%) — arbitrary syscall confirmed
VULN-09	MySQL — Default Root Credentials with Empty Password (Port 3306/tcp)	**Critical**	9.8	Greenbone OpenVAS (QoD 95%) — root login with empty password confirmed
VULN-10	PostgreSQL — Default Credentials (Port 5432/tcp)	**Critical**	9.0	Greenbone OpenVAS (QoD 99%) — login as 'postgres' with password 'postgres' confirmed
VULN-11	DistCC — Unauthenticated Remote Code Execution (CVE-2004-2687, Port 3632/tcp)	**Critical**	9.3	Greenbone OpenVAS (QoD 99%) — 'id' command execution confirmed: uid=1(daemon) gid=1(daemon)
VULN-12	SSL Version 2 and 3 — Deprecated Protocol Enabled	**Critical**	9.8	Nessus (Plugin 20007)
VULN-13	Debian OpenSSH/OpenSSL Weak Pseudo-Random Number Generator (CVE-2008-0166)	**Critical**	10.0	Nessus (Plugins 32314, 32320, 32321)
VULN-14	End-of-Life Operating System — Ubuntu 8.04 (Hardy Heron, EOL May 2013)	**Critical**	10.0	Nessus (Plugin 201352)
VULN-15	End-of-Life Software — Apache Tomcat 5.5.x (EOL September 2012)	**Critical**	10.0	Nessus (Plugin 171340)
VULN-16	rexec / rlogin / rsh Services — Unauthenticated and Passwordless Root Access (Ports 512–514/tcp)	**High**	10.0	Greenbone OpenVAS (rexec Critical CVSS 10.0 QoD 80%
VULN-17	HTTP PUT and DELETE Methods Enabled — Arbitrary File Upload via WebDAV (Port 80/tcp)	**High**	7.5	Greenbone OpenVAS (QoD 99%) — file upload and deletion confirmed at http://10.0.2.4/dav/
VULN-18	SQL Injection — Web Application (Multiple Endpoints)	**High**	8.8	Greenbone OpenVAS (DVWA SQL Injection — Blind, confirmed)
VULN-19	Cross-Site Scripting (XSS) — Reflected and Stored (1,100+ Instances)	**High**	8.8	ZAP (1,121 reflected XSS, 4 stored XSS)
VULN-20	NFS Shares — World-Readable Unauthenticated Access	**High**	7.5	Nessus (Plugin 42256)

VULN-21	Samba — Badlock (CVE-2016-2118) and MS-RPC Remote Code Execution (CVE-2007-2447)	**High**	7.5	Nessus (Plugin 90509, EPSS 0.7714) — Badlock
VULN-22	FTP Services — Default and Weak Credentials Accepted (Ports 21/tcp and 2121/tcp)	**High**	7.5	Greenbone OpenVAS (QoD 95%, both ports) — confirmed login with: msfadmin:msfadmin, postgres:postgres, service:service, user:user
VULN-23	Path Traversal — Arbitrary File Read (30 Instances)	**High**	7.5	ZAP (30 confirmed instances)
VULN-24	Remote File Inclusion (RFI) — Arbitrary Remote Script Execution (1 Instance)	**High**	7.5	ZAP (1 confirmed instance — High severity)
VULN-25	Server Side Include (SSI) Injection — Remote Code Execution (1 Instance)	**High**	7.5	ZAP (1 confirmed instance — High severity)
VULN-26	OpenSSL CCS Injection — Man-in-the-Middle (CVE-2014-0224)	**High**	7.4	Greenbone OpenVAS (QoD 70%) — confirmed on port 5432/tcp (PostgreSQL TLS)
VULN-27	Unencrypted Telnet Server (Port 23/tcp)	**Medium**	6.5	Nessus (Plugin 42263)
VULN-28	Multiple SSL/TLS Cryptographic Weaknesses (DROWN, SWEET32, POODLE, RC4, FREAK, Logjam)	**Medium**	7.5	Nessus (Plugins 89058, 42873, 78479, 65821, 81606, 83875, 83738)
VULN-29	DNS Cache Snooping and Cache Poisoning — ISC BIND EOL (CVE-2008-1447)	**Medium**	6.8	Nessus (Plugins 33447, 136769, 136808, 139915)
VULN-30	HTTP TRACE Method Enabled — Cross-Site Tracing (XST)	**Medium**	5.3	Nessus (Plugin 11213, EPSS 0.6899)
VULN-31	Missing Security Headers — X-Frame-Options, X-Content-Type-Options, Content-Security-Policy	**Medium**	5.3	Nikto (X-Frame-Options absent, X-Content-Type-Options absent)
VULN-32	Application Error Disclosure — Debug Information in HTTP Responses (211 Instances)	**Medium**	5.3	ZAP (211 instances — Application Error Disclosure, Medium)
VULN-33	SSH Weak Algorithms — CBC Ciphers, Weak MAC, Weak Key Exchange	**Low**	3.7	Nessus (Plugins 70658, 71049, 153953)
VULN-34	Open Redirect — Unvalidated Redirect Destinations (211 Instances)	**Low**	4.7	ZAP (211 instances — External Redirect)
VULN-35	Information Disclosure — PHP Version, Server Tokens, X-Powered-By Header	**Low**	5.3	Nikto (X-Powered-By: PHP/5.2.4-2ubuntu5.10)
VULN-36	Debug Error Messages — Verbose Server-Side Error Output (253 Instances)	**Low**	5.3	ZAP (253 instances — Information Disclosure: Debug Error Messages, Low)

VULN-37	ICMP Timestamp Disclosure	**Low**	2.1	Nessus (Plugin 10114)
VULN-38	Apache mod_negotiation MultiViews — Filename Brute Force Enabled	**Informational**	N/A	Nikto (/index: Apache mod_negotiation enabled with MultiViews)
VULN-39	Web Server Responds to Arbitrary HTTP Methods	**Informational**	N/A	Nikto (Web Server returns valid response with junk HTTP methods)
VULN-40	X Server Detected — Graphical Display Accessible (Port 6000/tcp)	**Informational**	N/A	Nessus (Plugin 10407)
VULN-41	IRC Daemon — Unnecessary Service on Network Perimeter	**Informational**	N/A	Nessus (Plugin 11156 — IRC Daemon Version Detection)
VULN-42	Absence of Anti-CSRF Tokens — Application-Wide	**Informational**	N/A	ZAP (Systemic — Absence of Anti-CSRF Tokens, Medium flagged as Systemic)
VULN-43	Apache Tomcat Manager — Default Credentials Accepted	**Critical**	9.8	Qualys VMDR (Basic + Credentialed Scans — default admin credentials confirmed)
VULN-44	TFTP Service — Unauthenticated File Access Including /etc/passwd	**High**	7.5	Qualys VMDR (Basic + Credentialed Scans — /etc/passwd retrieval and directory traversal confirmed)
VULN-45	SMB Signing Not Required — NTLM Relay Attack Surface	**Medium**	5.3	Nessus Basic + Credentialed Scans (Plugin 57608 — SMB Signing not required)
VULN-46	phpMyAdmin — Multiple XSS and CSRF Vulnerabilities (PMASA Advisories)	**Medium**	6.1	Qualys VMDR (Basic + Credentialed Scans — four PMASA advisories confirmed)
VULN-47	Apache Log4j 1.x — End-of-Life with Known Remote Code Execution (CVE-2019-17571)	**High**	8.1	Qualys VMDR (Credentialed Scan — Log4j 1.x EOL confirmed; CVE-2019-17571 RCE applicable)
VULN-48	.rhosts File and hosts.equiv Wildcard — Passwordless Remote Login Confirmed	**High**	7.5	Qualys VMDR (Credentialed Scan — .rhosts files and + wildcard in /etc/hosts.equiv confirmed)
VULN-49	SMTP VRFY Command — Valid User Account Enumeration Confirmed	**Medium**	5.0	Qualys VMDR (Credentialed Scan — valid logins enumerated via VRFY); Greenbone OpenVAS (SMTP VRFY/EXPN active)

VULN-50	Anonymous FTP Login Permitted	Medium	5.0	Qualys VMDR (Basic + Credentialed Scans); Greenbone OpenVAS (Anonymous FTP Login confirmed on port 21/tcp)
VULN-51	ZAP: MD5 Crypt Password Hash Exposed in HTTP Response	High	7.5	ZAP Active Scan (Hash Disclosure — MD5 Crypt, 1 confirmed instance at /mutillidae/index.php)
VULN-52	SSL Anonymous Cipher Suites Supported — Unauthenticated TLS Possible	Medium	5.9	Nessus Basic + Credentialed Scans (Plugin 31705 — SSL Anonymous Cipher Suites Supported)
VULN-53	Vulnerable JavaScript Library — jQuery 1.3.2 XSS (CVE-2012-6708 / CVE-2011-4969)	Medium	6.1	ZAP (Vulnerable JS Library — jQuery at /mutillidae/javascript/); Greenbone OpenVAS (jQuery < 1.9.0 XSS confirmed)
VULN-54	Directory Browsing Enabled — /dav/ and /doc/ Listings Exposed	Medium	5.3	ZAP (2 confirmed instances — /dav/ directory); Greenbone OpenVAS (/doc/ directory browsable)
VULN-55	Session Cookies Missing HttpOnly and SameSite Flags (4 Confirmed Instances)	Low	3.7	ZAP (4 confirmed Cookie No HttpOnly Flag instances; SameSite absent systemic)
VULN-56	Private IP Address Disclosed in HTTP Responses (25 Instances)	Low	3.1	ZAP (25 confirmed instances of internal IP address disclosure in HTTP responses)
VULN-57	ProFTPD 1.3.3c Backdoor — Unauthenticated Root Shell (Port 2121/tcp)	Critical	10.0	Greenbone OpenVAS (CVE-2011-2523 QoD 99%); Qualys VMDR
VULN-58	Apache Tomcat Manager — Default Credentials on Port 8180 (tomcat:tomcat)	Critical	9.8	Qualys VMDR Basic Scan (port 8180/tcp confirmed)
VULN-59	Samba Out-of-Bounds Heap R/W RCE (CVE-2021-44142) via vfs_fruit	Critical	9.8	Qualys VMDR Basic + Credentialed Scans
VULN-60	TikiWiki Exposed Installer — /tikiwiki/tiki-install.php Accessible	High	7.5	Greenbone OpenVAS (QoD 80%)
VULN-61	Samba NMBD Heap Overflow — NDR Parsing RCE (CVE-2007-2446)	High	7.8	Qualys VMDR Basic + Credentialed Scans
VULN-62	UnrealIRCd Certificate Fingerprint Spoofing (CVE-2016-7144)	High	7.5	Greenbone OpenVAS (separate NVT from VULN-03)
VULN-63	phpinfo.php Unauthenticated RCE Vector — Active Code Execution (QoD 99%)	High	7.5	Greenbone OpenVAS (EasyPHP NVT QoD 99%)

VULN-64	phpMyAdmin /scripts/setup.php Remote Code Injection (CVE-2009-1151)	**High**	7.5	Qualys VMDR Basic Scan (Metasploit module confirmed)
VULN-65	TWiki 'rev' Parameter Shell RCE (CVE-2005-2877) — Distinct from CVE-2008-5305	**High**	7.5	Qualys VMDR Basic Scan (Metasploit module: twiki_history)
VULN-66	PHP CGI Source Code Disclosure via -s Flag (9 ZAP Confirmed Instances)	**High**	7.5	ZAP Active Scan (9 confirmed instances; full source returned)
VULN-67	Samba RC4/HMAC Weak Hash Downgrade (CVE-2022-45141)	**High**	8.1	Qualys VMDR Basic Scan (Samba < 4.15.13)
VULN-68	NFS-Utils Xlog Remote Buffer Overflow via mountd (CVE-2003-0252)	**High**	7.5	Qualys VMDR Basic Scan (QID 68521; Severity 5)
VULN-69	Samba receive_smb_raw() Heap Buffer Overflow RCE (CVE-2008-1105)	**High**	7.9	Qualys VMDR Basic + Credentialed Scans (3.0.0-3.0.29)
VULN-70	Samba chain_reply() Memory Corruption (CVE-2010-2063)	**High**	7.5	Qualys VMDR Basic Scan (Samba before 3.4.8)
VULN-71	Samba MS-RPC Code Generator Heap Overflow — Root RCE (CVE-2012-1182)	**High**	8.3	Qualys VMDR Basic Scan (all Samba <= 3.6.3)
VULN-72	Samba send_mailslot() Heap Overflow (CVE-2007-6015)	**High**	7.5	Qualys VMDR Basic Scan (Samba < 3.0.28)
VULN-73	ProFTPD mod_sql SQL Injection and Buffer Overflow (CVE-2009-0542/0543)	**High**	7.5	Qualys VMDR Basic + Credentialed Scans (ProFTPD 1.3.1)
VULN-74	ProFTPD Response Pool Use-After-Free and SFTP Vulnerabilities (CVE-2011-4130)	**High**	7.5	Qualys VMDR Basic Scan (ProFTPD 1.3.1 port 2121/tcp)
VULN-75	PHP CGI Post-Patch Bypass Variants (CVE-2012-2335/CVE-2012-2336)	**High**	7.5	Qualys VMDR Basic + Credentialed Scans (PHP 5.2.4)
VULN-76	Apache Range Header DoS — Apache Killer (CVE-2011-3192)	**High**	7.8	Qualys VMDR Basic Scan (Apache 2.2.8 < 2.2.21)
VULN-77	Apache HTTP Server 2.2.x End-of-Life — No Updates Since July 2017	**High**	8.0	Qualys VMDR Basic Scan (Severity 5; EOL confirmed)
VULN-78	Java RMI Registry Exposed — Unauthenticated Remote Method Invocation	**Medium**	6.5	Nessus Basic + Credentialed Scans (Plugin 22227)
VULN-79	SSL/TLS Renegotiation CPU Exhaustion DoS (CVE-2011-1473/CVE-2011-5094)	**Medium**	4.3	Greenbone OpenVAS (QoD 70%; 10 renegotiations induced)
VULN-80	TWiki Cross-Site Request Forgery (CVE-2009-4898)	**Medium**	6.1	Greenbone OpenVAS (TWiki CSRF NVT QoD 80%)
VULN-81	Mutillidae Local File Inclusion — Active /etc/passwd Read Confirmed (QoD 99%)	**Medium**	5.0	Greenbone OpenVAS (awiki LFI NVT QoD 99%)

VULN-82	phpMyAdmin error.php Stored XSS (CVE-2010-4480) — QoD 99% Confirmed	**Medium**	4.3	Greenbone OpenVAS (QoD 99%; CVE-2010-4480)
VULN-83	Cleartext Credential Transmission — Four Applications Confirmed Over HTTP	**Medium**	4.3	Greenbone OpenVAS (Cleartext NVT QoD 80%; 4 apps)
VULN-84	Vim < 9.1.2132 Heap Buffer Overflow (GHSA-5w93-4g67-mm43)	**Medium**	6.6	Nessus Credentialed Scan (Plugin 298656)
VULN-85	PostgreSQL PassTheHash — MD5 Authentication Protocol Weakness	**Medium**	6.5	Qualys VMDR Credentialed Scan (QID 373102)
VULN-86	Apache OptionsBleed — Memory Disclosure via OPTIONS Method (CVE-2017-9798)	**Medium**	5.9	Qualys VMDR Credentialed Scan (CVE-2017-9798)
VULN-87	OpenSSH LoginGraceTime/MaxStartups DoS — Connection Slot Exhaustion	**Medium**	5.3	Qualys VMDR Basic + Credentialed Scans
VULN-88	Samba SWAT XSS and CSRF (CVE-2011-2522/CVE-2011-2694)	**Medium**	6.1	Qualys VMDR Basic Scan (Samba 3.0.x-3.5.9)
VULN-89	Samba Symlink Directory Traversal — Zero Day (CVE-2010-0926)	**Medium**	5.8	Qualys VMDR Basic Scan (Metasploit module confirmed)
VULN-90	ProFTPD Directory Traversal and Buffer Overflow (CVE-2010-3867)	**Medium**	5.8	Qualys VMDR Basic Scan (ProFTPD 1.3.1 confirmed)
VULN-91	PHP Session Fixation (CVE-2011-4718)	**Medium**	5.8	Qualys VMDR Basic Scan (PHP 5.2.4 port 80/tcp)
VULN-92	APR-util Library Integer Overflow — Remote Code Execution Vector	**Medium**	5.1	Qualys VMDR Basic Scan (Apache 2.2.8 APR-util)
VULN-93	OpenSSH Username Enumeration via Timing Side-Channel (CVE-2016-6210)	**Medium**	5.3	Qualys VMDR Basic Scan (OpenSSH 4.7p1 < 7.3)
VULN-94	OpenSSH X11 Hijacking Attack (CVE-2008-1483)	**Medium**	6.9	Qualys VMDR Basic Scan (OpenSSH 4.7p1 < 5.0)
VULN-95	OpenSSH CRLF Injection via X11 Forwarding (CVE-2016-3115)	**Medium**	5.5	Qualys VMDR Basic Scan (OpenSSH 4.7p1 < 7.2p2)
VULN-96	Apache mod_setenvif Integer Overflow — Heap Buffer Overflow (CVE-2011-3607)	**Medium**	4.4	Qualys VMDR Basic Scan (Apache 2.2.8 < 2.2.21)
VULN-97	jQuery 1.3.2 Additional CVEs — Prototype Pollution and XSS (CVE-2019-11358 et al.)	**Medium**	6.1	ZAP Active Scan (CVE-2019-11358, CVE-2020-11022/23, CVE-2020-7656)
VULN-98	SSL Certificate RSA Public Key Strength Below 2048 Bits	**Medium**	5.3	Greenbone OpenVAS (SSL RSA key < 2048 bits NVT)
VULN-99	Unix Timestamp Disclosure — Systemic Across TWiki Application Pages	**Low**	3.1	ZAP Active Scan (Timestamp Disclosure; systemic via TWiki pages)

VULN-100	SSH Server Weak Host Key Algorithm Supported	**Low**	3.7	Greenbone OpenVAS (Weak Host Key Algorithm NVT; port 22/tcp)
VULN-101	Harvest Now / Decrypt Later — Post-Quantum Cipher Exposure Risk	**Informational**	N/A	Nessus Basic + Credentialed Scans (Plugins 277650, 298387)

7.4 Detailed Findings

Full technical detail for each of the 56 identified vulnerabilities:

VULN-01 — Bind Shell Backdoor — Unauthenticated Root Shell (Port 1524/tcp)	
Severity	Critical
CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	No CVE (intentional backdoor — Ingreslock)
Detected By	Greenbone OpenVAS (QoD 99%); Qualys (Severity 5); Nessus (Plugin 51988)
Description	An unauthenticated bind shell listens on port 1524/tcp. Any remote connection is immediately granted a root shell (uid=0). Greenbone confirmed exploitation by sending an 'id;' command and receiving 'uid=0(root) gid=0(root)' in response.
Impact	Complete and immediate system compromise. Any unauthenticated user on the network can obtain full root access, execute arbitrary commands, exfiltrate all data, and pivot to other hosts.
Remediation	Immediately shut down port 1524 and remove the backdoor process. Block the port at the network firewall. Treat the host as fully compromised — perform a full forensic investigation and rebuild from a trusted image.

VULN-02 — vsftpd 2.3.4 Compromised Package Backdoor (Port 6200/tcp)	
Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2011-2523
Detected By	Greenbone OpenVAS (QoD 99%); Qualys (Severity 5); Nessus (Plugin 21745)
Description	The vsftpd 2.3.4 package is a known trojanised release distributed between 2011-06-30 and 2011-07-03. A specific trigger sequence sent to the FTP service opens a command shell on port 6200/tcp granting unauthenticated remote code execution. Greenbone confirmed successful exploitation.
Impact	Unauthenticated remote command execution in the context of the vsftpd process, providing a reliable path to full root access.
Remediation	Remove vsftpd 2.3.4 immediately and replace with a verified clean version (vsftpd 3.0.x). Block port 6200 at the firewall. Verify binary integrity against known-good checksums.

VULN-03 — UnrealIRCd 3.2.8.1 Backdoor — RCE (CVE-2010-2075) and Authentication Spoofing (CVE-2016-7144)	
Severity	Critical
CVSS Rating	10.0 / 8.1 (CVSS v3.0)

CVE / CWE	CVE-2010-2075; CVE-2016-7144
Detected By	Nessus (Plugin 46882, EPSS 0.8581); Greenbone OpenVAS (QoD 99% backdoor; QoD 80% spoofing); Qualys (Severity 5)
Description	Two distinct vulnerabilities affect the UnrealIRCd installation. First, a hardcoded backdoor (CVE-2010-2075) allows unauthenticated RCE by sending the string 'AB;' to the IRC port. Second, a flaw in the m_authenticate function (CVE-2016-7144) allows certificate fingerprint spoofing and user impersonation. Both affect version 3.2.8.1.
Impact	CVE-2010-2075: unauthenticated arbitrary OS command execution. CVE-2016-7144: remote authentication bypass and user impersonation on the IRC service.
Remediation	Remove UnrealIRCd immediately. If IRC is required, upgrade to version 4.0.6 or later from a trusted, verified source. Block IRC ports (6667, 6697) at the perimeter firewall.

VULN-04 — Shellshock — Bash Remote Code Execution (CVE-2014-6271 / CVE-2014-7169)

Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2014-6271; CVE-2014-7169
Detected By	Nessus SSH scan (Plugin 77823, VPR 9.6, EPSS 0.9422); Qualys SSH scan (Severity 5, QID 122693); ZAP (2 confirmed instances)
Description	The installed version of Bash processes specially crafted environment variables as executable commands. This allows unauthenticated remote code execution through any service that passes user-controlled data as environment variables to Bash, including CGI scripts, SSH, FTP, DHCP, and SMTP. EPSS 0.9422 indicates near-certain real-world exploitation. ZAP confirmed 2 active instances via HTTP.
Impact	Unauthenticated remote code execution across multiple service vectors simultaneously. An attacker can achieve a reverse shell, read arbitrary files, modify system configuration, or pivot to other hosts.
Remediation	Patch Bash to version 4.3 patch 25 or later. Apply all available OS security updates. Disable mod_cgi in Apache if CGI is not required.

VULN-05 — Apache Tomcat Ghostcat — AJP Connector Request Injection (CVE-2020-1938)

Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2020-1938
Detected By	Nessus (Plugin 134862, VPR 8.9, EPSS 0.9447); Qualys (Severity 5); Greenbone OpenVAS (QoD 99%) — file read of /WEB-INF/web.xml confirmed
Description	The Apache Tomcat AJP connector on port 8009 is exposed and unprotected. Ghostcat allows unauthenticated attackers to read any file from the web application, including WEB-INF/web.xml. Greenbone confirmed successful file retrieval. EPSS 0.9447 indicates near-certain real-world exploitation. Listed in the CISA KEV catalogue.
Impact	Unauthenticated file read of any web application resource. If file upload is possible, full remote code execution is achievable.
Remediation	Upgrade Apache Tomcat to 9.0.31+, 8.5.51+, or 7.0.100+. If the AJP connector is not required, disable it in server.xml. If required, restrict AJP to localhost and set the requiredSecret attribute.

VULN-06 — VNC Server — Default Password 'password' (Port 5900/tcp)

Severity	Critical

CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	CWE-521 (Weak Credentials)
Detected By	Nessus (Plugin 61708); Greenbone OpenVAS (VNC Brute Force Login, QoD 95%); Qualys (Severity 5)
Description	The VNC server on port 5900 accepts the password 'password'. Greenbone confirmed successful connection. An authenticated VNC session provides full graphical desktop access equivalent to physical console access.
Impact	Any remote user with network access to port 5900 gains full interactive graphical desktop access with ability to run commands, read and write files, and install persistence mechanisms.
Remediation	Set a strong, unique VNC password of at least 16 characters. Restrict VNC access to trusted management IPs at the firewall. Consider replacing VNC with SSH tunnelling.

VULN-07 — PHP CGI Remote Code Execution (CVE-2012-1823)

Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2012-1823; CVE-2012-2311
Detected By	Greenbone OpenVAS (QoD 95%, CISA KEV — phpinfo() execution confirmed); ZAP (28 instances)
Description	PHP running in CGI mode allows unauthenticated attackers to pass command-line switches directly to the PHP binary via the query string. Greenbone confirmed execution by posting a PHP payload and receiving a full phpinfo() response. ZAP detected 28 instances. This CVE is listed in the CISA Known Exploited Vulnerabilities catalogue.
Impact	Unauthenticated remote code execution. An attacker can read PHP source code and execute arbitrary PHP, achieving a full server shell.
Remediation	Upgrade PHP to a currently supported release (8.1+). Disable PHP CGI mode; use mod_php or PHP-FPM instead. Set cgi.force_redirect=1 in php.ini.

VULN-08 — Distributed Ruby (dRuby/DRb) — Unauthenticated Remote Code Execution (Port 8787/tcp)

Severity	Critical
CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	No CVE (design flaw in dRuby configuration)
Detected By	Greenbone OpenVAS (QoD 99%) — arbitrary syscall confirmed
Description	The dRuby/DRb service on port 8787 is running without access controls. Greenbone confirmed the ability to invoke arbitrary syscalls, receiving error responses that confirm code execution. By default, dRuby does not restrict which hosts can submit commands.
Impact	Unauthenticated arbitrary command execution with the privileges of the dRuby process. An attacker can enumerate files, read credentials, write files, and establish persistence.
Remediation	Disable the dRuby service if not required. If required, implement ACL restrictions using drb/acl.rb and set $SAFE >= 2. Bind to localhost only. Block port 8787 at the firewall.

VULN-09 — MySQL — Default Root Credentials with Empty Password (Port 3306/tcp)

Severity	Critical

CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	No CVE (configuration issue)
Detected By	Greenbone OpenVAS (QoD 95%) — root login with empty password confirmed
Description	The MySQL 5.0.51a service on port 3306 accepts a login as user 'root' with an empty password. Greenbone confirmed successful authentication. This provides full administrative access to all databases on the system.
Impact	Complete database compromise — full read, write, and administrative access to all data. With MySQL FILE privileges, an attacker can read arbitrary files from the filesystem and write files to accessible paths, enabling further system compromise.
Remediation	Immediately set a strong password for the MySQL root account. Restrict MySQL to listen on localhost only (bind-address=127.0.0.1). Remove all anonymous user accounts. Review and restrict all user privileges.

VULN-10 — PostgreSQL — Default Credentials (Port 5432/tcp)

Severity	Critical
CVSS Rating	9.0 (CVSS v3.0)
CVE / CWE	No CVE (configuration issue)
Detected By	Greenbone OpenVAS (QoD 99%) — login as 'postgres' with password 'postgres' confirmed
Description	The PostgreSQL 8.3.1 service on port 5432 accepts a login as user 'postgres' with password 'postgres'. Greenbone confirmed successful authentication at QoD 99%, granting full administrative access to all PostgreSQL databases on the system.
Impact	Complete PostgreSQL database compromise — full read, write, create, and drop access across all databases. An attacker can exfiltrate all stored data, modify records, and potentially use COPY TO/FROM PROGRAM for OS-level command execution.
Remediation	Immediately change the password for the 'postgres' superuser account. Restrict PostgreSQL to listen on localhost only. Review pg_hba.conf to enforce md5 or scram-sha-256 authentication. Remove or restrict all other default accounts.

VULN-11 — DistCC — Unauthenticated Remote Code Execution (CVE-2004-2687, Port 3632/tcp)

Severity	Critical
CVSS Rating	9.3 (CVSS v3.0)
CVE / CWE	CVE-2004-2687
Detected By	Greenbone OpenVAS (QoD 99%) — 'id' command execution confirmed: uid=1(daemon) gid=1(daemon)
Description	DistCC 2.x is running on port 3632 without access controls. By default DistCC trusts all clients completely. Greenbone confirmed remote code execution by running the 'id' command and receiving 'uid=1(daemon) gid=1(daemon)' in response.
Impact	Unauthenticated remote code execution as the daemon user. Combined with local privilege escalation vulnerabilities present on this EOL system, this provides a path to full root access.
Remediation	Disable the DistCC service if not required for active use. If required, restrict access via DistCC's DISTCC_HOSTS allowlist and firewall rules to trusted build clients only. Block port 3632 at the network perimeter.

VULN-12 — SSL Version 2 and 3 — Deprecated Protocol Enabled

Severity	Critical

CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2014-3566 (POODLE); CVE-2016-0800 (DROWN)
Detected By	Nessus (Plugin 20007); Qualys (Severity 5); Greenbone OpenVAS
Description	SSLv2 and SSLv3 are enabled across multiple services. SSLv2 is directly exploitable via the DROWN attack to decrypt RSA-encrypted traffic. SSLv3 is vulnerable to POODLE. Both protocols have been deprecated for over a decade.
Impact	A network attacker can decrypt TLS-encrypted traffic by exploiting DROWN or POODLE, recovering plaintext credentials, session tokens, and sensitive data in transit.
Remediation	Disable SSLv2 and SSLv3 on all services. Configure a minimum TLS version of 1.2. Apply cipher hardening to remove RC4, DES, and export cipher suites.

VULN-13 — Debian OpenSSH/OpenSSL Weak Pseudo-Random Number Generator (CVE-2008-0166)

Severity	Critical
CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	CVE-2008-0166
Detected By	Nessus (Plugins 32314, 32320, 32321); Qualys (Severity 5)
Description	Due to a flawed patch in Debian/Ubuntu, the OpenSSL package uses a predictable PRNG, making all cryptographic keys generated on this system computationally weak. All SSL/TLS certificates, SSH host keys, and user SSH keys generated on this machine are potentially guessable. Nessus confirmed weak SSH keys are present in ~/.ssh/authorized_keys.
Impact	All SSL/SSH keys generated on this system can be precomputed using publicly available rainbow tables. An attacker can authenticate as any user whose key was generated on this system.
Remediation	Immediately revoke all SSL certificates and SSH keys generated on this system. Regenerate all keys on a fully patched system. Remove weak keys from ~/.ssh/authorized_keys and all trust stores.

VULN-14 — End-of-Life Operating System — Ubuntu 8.04 (Hardy Heron, EOL May 2013)

Severity	Critical
CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	CWE-1104
Detected By	Nessus (Plugin 201352); Qualys (Severity 5, QID 105604, PCI Violation); Greenbone OpenVAS
Description	The host is running Ubuntu 8.04, which reached end of life in May 2013. No security patches have been available for over a decade. This single finding is the root cause of the majority of the 383+ CVEs detected by Nessus, covering the Linux kernel, glibc, OpenSSL, Apache, PHP, Samba, and virtually every other system component.
Impact	The system is exposed to over a decade of unpatched vulnerabilities across every installed package, making every service trivially exploitable.
Remediation	Migrate to a currently supported Ubuntu LTS release (22.04 or 24.04 LTS). Build from a trusted base image and apply all security updates before deploying services. This single action resolves the majority of findings in this report.

VULN-15 — End-of-Life Software — Apache Tomcat 5.5.x (EOL September 2012)

Severity	Critical

CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	CWE-1104
Detected By	Nessus (Plugin 171340); Qualys (Severity 5, QID 105905)
Description	Apache Tomcat 5.5.x has received no security updates since September 2012. This version is directly affected by the Ghostcat vulnerability (VULN-05). Default Tomcat example applications are also present (Nessus Plugin 12085), further expanding the attack surface.
Impact	All known Tomcat 5.5 CVEs are permanently unpatched. Default example applications provide additional exploit vectors.
Remediation	Upgrade to Apache Tomcat 10.1.x or 11.0.x. Remove all default example applications. Migrate application code as required for Jakarta EE namespace changes.

VULN-16 — rexec / rlogin / rsh Services — Unauthenticated and Passwordless Root Access (Ports 512–514/tcp)

Severity	High
CVSS Rating	10.0 (CVSS v2.0) — re-classified High per CVSS v3.0 baseline
CVE / CWE	CVE-1999-0618; CVE-1999-0651
Detected By	Greenbone OpenVAS (rexec Critical CVSS 10.0 QoD 80%; rlogin Passwordless Login confirmed QoD 80%); Nessus (Plugins 10205, 10245); Qualys
Description	Three legacy remote access services are running: rexec (512/tcp), rlogin (513/tcp), and rsh (514/tcp). Greenbone confirmed that rexec is running and classified it Critical (CVSS 10.0), and separately confirmed that rlogin allows root access without a password. All services transmit credentials in cleartext.
Impact	Any host with network access can obtain an interactive root shell without credentials. All session data including any prompted passwords is transmitted in cleartext.
Remediation	Disable and remove all three services immediately. Remove all .rhosts and /etc/hosts.equiv files. Block ports 512–514 at the firewall. Replace with SSH for all remote administration.

VULN-17 — HTTP PUT and DELETE Methods Enabled — Arbitrary File Upload via WebDAV (Port 80/tcp)

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CWE-650
Detected By	Greenbone OpenVAS (QoD 99%) — file upload and deletion confirmed at http://10.0.2.4/dav/
Description	The Apache web server allows the HTTP PUT and DELETE methods on the WebDAV-enabled directory. Greenbone confirmed successful upload of a test file and subsequent deletion via these methods. Unrestricted PUT access allows an attacker to upload arbitrary files, including server-side scripts, directly to the web server.
Impact	An attacker can upload a PHP webshell or other executable file and achieve remote code execution in the context of the web server process. DELETE access allows destruction of existing content.
Remediation	Disable WebDAV or restrict PUT and DELETE methods using Apache's LimitExcept directive. If WebDAV is required, enforce authentication. Review all directories where PUT is enabled.

VULN-18 — SQL Injection — Web Application (Multiple Endpoints)

Severity	High
CVSS Rating	8.8 (CVSS v3.0)
CVE / CWE	CWE-89 / WASC-19
Detected By	Greenbone OpenVAS (DVWA SQL Injection — Blind, confirmed); ZAP (5 confirmed instances)
Description	SQL injection vulnerabilities are present across the web application (DVWA, Mutillidae). Greenbone confirmed blind SQL injection in DVWA. ZAP confirmed 5 instances. User input is concatenated directly into SQL queries without sanitisation or parameterisation. Raw database error messages are returned to the browser.
Impact	Complete database compromise — extraction, modification, or deletion of all records. Depending on database user privileges, OS-level command execution may be achievable.
Remediation	Replace all dynamic SQL with PDO prepared statements or MySQLi parameterised queries. Apply server-side input validation. Restrict MySQL account privileges. Suppress all database error messages from end users.

VULN-19 — Cross-Site Scripting (XSS) — Reflected and Stored (1,100+ Instances)

Severity	High
CVSS Rating	8.8 (CVSS v3.0)
CVE / CWE	CWE-79 / WASC-8
Detected By	ZAP (1,121 reflected XSS, 4 stored XSS); Greenbone OpenVAS (TWiki XSS/Command Execution, CVE-2008-5304/5305)
Description	Over 1,100 instances of reflected XSS were identified across the web application (Mutillidae, TWiki), along with 4 stored XSS vulnerabilities in TWiki. Greenbone additionally confirmed TWiki command execution via eval injection (CVE-2008-5305). User-supplied data is rendered in HTML without any encoding or sanitisation.
Impact	Session hijacking via cookie theft, credential phishing, drive-by malware delivery, and keylogging. Stored XSS affects every subsequent visitor without requiring further attacker action.
Remediation	Implement output encoding on all user-controlled data. Set HttpOnly and Secure flags on session cookies. Implement a Content-Security-Policy header. Upgrade TWiki to 4.2.4 or later.

VULN-20 — NFS Shares — World-Readable Unauthenticated Access

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CWE-284
Detected By	Nessus (Plugin 42256); Qualys (Severity 4)
Description	Network File System shares are exported without authentication, allowing any host on the network to mount and read share contents. With no_root_squash settings, a remote attacker with a crafted UID of 0 can read or write as root.
Impact	Unauthenticated read access to all exported files, potentially including SSH private keys, application credentials, and database configuration. With no_root_squash, arbitrary file write is achievable.
Remediation	Restrict NFS exports to specific trusted IP addresses in /etc/exports. Require Kerberos authentication (sec=krb5). Disable no_root_squash. Consider replacing NFS with SFTP or SCP.

VULN-21 — Samba — Badlock (CVE-2016-2118) and MS-RPC Remote Code Execution (CVE-2007-2447)

Severity	High
CVSS Rating	7.5 / 6.0 (RCE confirmed)
CVE / CWE	CVE-2016-2118; CVE-2007-2447
Detected By	Nessus (Plugin 90509, EPSS 0.7714) — Badlock; Greenbone OpenVAS (QoD 99%) — RCE via crafted SMB request confirmed (ping callback received)
Description	Two distinct Samba vulnerabilities are present. CVE-2016-2118 (Badlock) enables man-in-the-middle attacks against SMB/DCE-RPC sessions. CVE-2007-2447 allows execution of arbitrary shell commands via a crafted MS-RPC request — Greenbone confirmed this by executing a ping command and receiving a response. Samba 3.0.20 is installed.
Impact	CVE-2016-2118: SMB session interception, credential theft, and privilege escalation. CVE-2007-2447: confirmed remote command execution in the context of the Samba process.
Remediation	Upgrade Samba to version 4.4.2 or later. Enable SMB signing (mandatory). Restrict SMB access to trusted internal networks. Block ports 139 and 445 at the perimeter.

VULN-22 — FTP Services — Default and Weak Credentials Accepted (Ports 21/tcp and 2121/tcp)

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CVE-1999-0501; CVE-1999-0502
Detected By	Greenbone OpenVAS (QoD 95%, both ports) — confirmed login with: msfadmin:msfadmin, postgres:postgres, service:service, user:user
Description	Both FTP services on ports 21 and 2121 accept multiple weak and default credential pairs. Greenbone confirmed successful login with four separate accounts. All FTP traffic including credentials is transmitted in cleartext.
Impact	Remote attackers can authenticate to FTP services and access, upload, or modify files. Credential reuse may enable lateral access to other services on the host.
Remediation	Remove all default and weak account credentials immediately. Disable FTP if not required, or enforce FTPS (AUTH TLS). Apply strong unique passwords and restrict access to authorised IP addresses only.

VULN-23 — Path Traversal — Arbitrary File Read (30 Instances)

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CWE-22 / WASC-33
Detected By	ZAP (30 confirmed instances); Greenbone OpenVAS (Mutillidae traversal confirmed: ../../../../../../etc/passwd read)
Description	ZAP detected 30 instances of path traversal across the web application. Greenbone confirmed successful traversal in the Mutillidae component, reading /etc/passwd via a null-byte injection. User-controlled file path parameters are not canonicalised or restricted to the web root.
Impact	Arbitrary file read outside the web root. Potential exposure of /etc/passwd, /etc/shadow, SSH private keys, database configuration files, and application source code.

Remediation	Validate all user-supplied file paths against a whitelist. Canonicalise paths and verify they remain within the intended base directory. Run the web server with minimal filesystem permissions.

VULN-24 — Remote File Inclusion (RFI) — Arbitrary Remote Script Execution (1 Instance)

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CWE-98 / WASC-5
Detected By	ZAP (1 confirmed instance — High severity)
Description	ZAP identified a Remote File Inclusion vulnerability in the web application. A user-controlled file path parameter accepts a remote URL, allowing an attacker to include and execute an arbitrary PHP script hosted on an attacker-controlled server.
Impact	Unauthenticated remote code execution in the context of the web server process. An attacker can serve a PHP webshell from any external host and execute it directly on the target server.
Remediation	Disable allow_url_include in php.ini. Validate all file-inclusion parameters against a strict whitelist of permitted local paths. Audit all include(), require(), and similar PHP functions for user-controlled input.

VULN-25 — Server Side Include (SSI) Injection — Remote Code Execution (1 Instance)

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CWE-97 / WASC-36
Detected By	ZAP (1 confirmed instance — High severity)
Description	ZAP detected a Server Side Include injection vulnerability. An attacker can inject SSI directives (e.g., <!--#exec cmd='id'-->) through user-controlled input that is written to and subsequently served as an SSI-enabled page, resulting in server-side command execution.
Impact	Remote code execution in the context of the web server process. An attacker can read files, execute system commands, and establish persistence via injected SSI directives.
Remediation	Disable SSI processing for all directories that do not require it (remove Includes from Options directive in Apache). Sanitise all user input that is stored and later served in web pages. Restrict filesystem access of the web server user.

VULN-26 — OpenSSL CCS Injection — Man-in-the-Middle (CVE-2014-0224)

Severity	High
CVSS Rating	7.4 (CVSS v3.0)
CVE / CWE	CVE-2014-0224
Detected By	Greenbone OpenVAS (QoD 70%) — confirmed on port 5432/tcp (PostgreSQL TLS)
Description	OpenSSL before version 0.9.8za does not properly restrict processing of ChangeCipherSpec (CCS) messages, allowing a man-in-the-middle attacker to trigger use of a zero-length master key in TLS handshakes. Detected on the PostgreSQL service on port 5432.
Impact	A network-positioned attacker can intercept and decrypt TLS-encrypted sessions, hijack active connections, and obtain sensitive data including database credentials and query results.

Remediation	Upgrade OpenSSL to version 0.9.8za, 1.0.0m, or 1.0.1h or later. Restart all services using OpenSSL after patching. As part of the OS migration (VULN-14), all OpenSSL libraries will be replaced.

VULN-27 — Unencrypted Telnet Server (Port 23/tcp)

Severity	Medium
CVSS Rating	6.5 (CVSS v3.0)
CVE / CWE	CWE-319
Detected By	Nessus (Plugin 42263); Greenbone OpenVAS (Medium — 23/tcp)
Description	Telnet transmits all data, including login credentials and session content, in plaintext over port 23.
Impact	Credential theft via passive network sniffing. Complete compromise of all remote administration activity conducted over Telnet.
Remediation	Disable the Telnet service. Block port 23 at the firewall. Replace with SSH for all remote administration.

VULN-28 — Multiple SSL/TLS Cryptographic Weaknesses (DROWN, SWEET32, POODLE, RC4, FREAK, Logjam)

Severity	Medium
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CVE-2016-0800; CVE-2016-2183; CVE-2014-3566; CVE-2015-3197
Detected By	Nessus (Plugins 89058, 42873, 78479, 65821, 81606, 83875, 83738); Qualys (Severity 3–4)
Description	Multiple distinct SSL/TLS cryptographic vulnerabilities are confirmed: DROWN (SSLv2, EPSS 0.8999), SWEET32 (3DES/64-bit block ciphers), POODLE (SSLv3, EPSS 0.9382), RC4 Bar Mitzvah (EPSS 0.9032), FREAK (512-bit export RSA, EPSS 0.9243), and Logjam (512-bit/1024-bit DH). High EPSS scores indicate these are actively exploited.
Impact	A network-positioned attacker can decrypt encrypted traffic, recover session cookies and credentials, and perform man-in-the-middle attacks via multiple simultaneous attack paths.
Remediation	Disable all insecure cipher suites and protocol versions. Enforce TLS 1.2 minimum (TLS 1.3 preferred). Use 2048-bit or larger DH parameters. Remove all export and RC4 cipher suites across all services.

VULN-29 — DNS Cache Snooping and Cache Poisoning — ISC BIND EOL (CVE-2008-1447)

Severity	Medium
CVSS Rating	6.8 (CVSS v3.0)
CVE / CWE	CVE-2008-1447; CVE-2021-25219
Detected By	Nessus (Plugins 33447, 136769, 136808, 139915); Qualys (Severity 5, QID 105508 — EOL BIND 9.4.x, PCI Violation)
Description	BIND DNS server version 9.4.x is EOL and vulnerable to cache poisoning, cache snooping, and two denial-of-service vulnerabilities (EPSS 0.9263 and 0.8691).
Impact	DNS cache poisoning enables traffic redirection to attacker-controlled servers. Cache snooping reveals internal network intelligence. DoS can disrupt all name resolution.
Remediation	Upgrade BIND to 9.18.x+. Restrict recursion to trusted clients. Disable version disclosure. Implement DNSSEC.

VULN-30 — HTTP TRACE Method Enabled — Cross-Site Tracing (XST)

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-16 / WASC-62
Detected By	Nessus (Plugin 11213, EPSS 0.6899); Nikto (HTTP TRACE active); ZAP
Description	The Apache web server responds to HTTP TRACE requests, echoing the full request including HTTP headers. Combined with the confirmed XSS vulnerabilities on this host, TRACE enables theft of HttpOnly cookies.
Impact	Theft of HttpOnly session cookies via Cross-Site Tracing, bypassing a primary XSS cookie-theft defence.
Remediation	Disable HTTP TRACE in Apache configuration: 'TraceEnable off'.

VULN-31 — Missing Security Headers — X-Frame-Options, X-Content-Type-Options, Content-Security-Policy

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-693
Detected By	Nikto (X-Frame-Options absent, X-Content-Type-Options absent); ZAP (Systemic — Missing Anti-Clickjacking Header, Missing CSP Header)
Description	The web application is missing all three primary client-side security headers. ZAP classified both findings as 'Systemic' — affecting the entire application.
Impact	Clickjacking, MIME-sniffing attacks, and completely unrestricted execution of all XSS payloads.
Remediation	Add all three headers to the Apache virtual host configuration: X-Frame-Options DENY, X-Content-Type-Options nosniff, Content-Security-Policy default-src 'self'.

VULN-32 — Application Error Disclosure — Debug Information in HTTP Responses (211 Instances)

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-209
Detected By	ZAP (211 instances — Application Error Disclosure, Medium)
Description	ZAP identified 211 instances where the application returns raw server-side error messages including stack traces, SQL errors, PHP error details, and file system paths.
Impact	Detailed internal information assists in escalating SQL injection and path traversal vulnerabilities. Database schema, file paths, and application logic are disclosed.
Remediation	Set display_errors=Off and log_errors=On in php.ini. Log errors server-side only. Implement generic error pages for all HTTP error codes.

VULN-33 — SSH Weak Algorithms — CBC Ciphers, Weak MAC, Weak Key Exchange

Severity	Low
CVSS Rating	3.7 (CVSS v3.0)
CVE / CWE	CWE-326

Detected By	Nessus (Plugins 70658, 71049, 153953); Greenbone OpenVAS (Medium — 22/tcp SSH weak algorithms)
Description	The SSH server supports CBC mode block ciphers, weak HMAC algorithms (MD5 and SHA-1), and weak key exchange algorithms (diffie-hellman-group1-sha1, Logjam-vulnerable).
Impact	A sophisticated network attacker may recover plaintext from CBC-encrypted SSH sessions or perform Logjam key exchange attacks.
Remediation	Update /etc/ssh/sshd_config: Ciphers aes256-ctr,aes192-ctr,aes128-ctr; MACs hmac-sha2-256,hmac-sha2-512; KexAlgorithms curve25519-sha256,diffie-hellman-group14-sha256.

VULN-34 — Open Redirect — Unvalidated Redirect Destinations (211 Instances)

Severity	Low
CVSS Rating	4.7 (CVSS v3.0)
CVE / CWE	CWE-601 / WASC-38
Detected By	ZAP (211 instances — External Redirect)
Description	ZAP detected 211 instances where user-controlled parameters are passed directly to redirect functions without validation.
Impact	Phishing attacks using the trusted application domain as a lure. Can be used to steal OAuth tokens if combined with OAuth flows.
Remediation	Validate all redirect targets against an allow-list of approved domains. Use indirect references (numeric IDs mapped to allowed URLs) server-side.

VULN-35 — Information Disclosure — PHP Version, Server Tokens, X-Powered-By Header

Severity	Low
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-200
Detected By	Nikto (X-Powered-By: PHP/5.2.4-2ubuntu5.10); ZAP (Server Leaks Version Information — Systemic)
Description	Every HTTP response discloses precise version information: PHP/5.2.4-2ubuntu5.10 and Apache/2.2.8 (Ubuntu) DAV/2. PHP 5.2.x is EOL with numerous known unpatched vulnerabilities.
Impact	Precise version information dramatically reduces attacker reconnaissance time and directly targets the applicable CVE list.
Remediation	Set expose_php=Off in php.ini. Set ServerTokens Prod and ServerSignature Off in Apache configuration. Upgrade PHP to a supported version (8.1+).

VULN-36 — Debug Error Messages — Verbose Server-Side Error Output (253 Instances)

Severity	Low
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-209
Detected By	ZAP (253 instances — Information Disclosure: Debug Error Messages, Low)
Description	ZAP detected 253 instances of debug-level error messages returned in HTTP responses, including verbose PHP notices, warnings, and internal path disclosures that expose implementation details without constituting full stack traces.

Impact	Assists attackers in fingerprinting application internals, identifying vulnerable code paths, and crafting more targeted injection attacks.
Remediation	Set error_reporting = E_ALL & ~E_NOTICE & ~E_DEPRECATED in php.ini and ensure display_errors=Off is applied globally. Review all error_reporting calls in application code.

VULN-37 — ICMP Timestamp Disclosure

Severity	Low
CVSS Rating	2.1 (CVSS v3.0)
CVE / CWE	CWE-200 (ICMP Type 13)
Detected By	Nessus (Plugin 10114)
Description	The host responds to ICMP timestamp requests, returning the system clock time. This can assist in defeating time-based authentication token schemes.
Impact	Minor information disclosure. May assist in timing-based attacks against time-dependent authentication.
Remediation	Add iptables rules to drop ICMP timestamp requests and replies. Persist rules with iptables-save.

VULN-38 — Apache mod_negotiation MultiViews — Filename Brute Force Enabled

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-16
Detected By	Nikto (/index: Apache mod_negotiation enabled with MultiViews)
Description	Apache mod_negotiation with MultiViews is enabled, confirming the existence of server-side files (e.g., index.php) without direct access.
Impact	Facilitates content discovery and attack surface mapping.
Remediation	Disable MultiViews: 'Options -MultiViews' in the relevant Directory or VirtualHost block.

VULN-39 — Web Server Responds to Arbitrary HTTP Methods

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-16
Detected By	Nikto (Web Server returns valid response with junk HTTP methods)
Description	The web server returns HTTP 200 to completely fabricated HTTP methods, indicating no method validation is enforced.
Impact	May mask method-based vulnerabilities from automated scanners and bypass method-based access controls.
Remediation	Configure Apache to restrict allowed HTTP methods using LimitExcept directives per directory.

VULN-40 — X Server Detected — Graphical Display Accessible (Port 6000/tcp)

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-284

Detected By	Nessus (Plugin 10407)
Description	An X Window System server is detected on port 6000/tcp. If XAUTHORITY is not enforced, remote attackers may capture screenshots or inject input.
Impact	If accessible without authentication, an attacker can passively monitor the graphical desktop or inject input.
Remediation	Set 'nolisten tcp' in X server startup. Restrict X11 forwarding to SSH tunnels only. Block port 6000 at the firewall.

VULN-41 — IRC Daemon — Unnecessary Service on Network Perimeter

Severity	Informational
CVSS Rating	N/A
CVE / CWE	N/A
Detected By	Nessus (Plugin 11156 — IRC Daemon Version Detection)
Description	An IRC daemon is detected and version information was enumerated. On this host, the IRC service is directly associated with the UnrealIRCd backdoor (VULN-03). Even if patched, running IRC increases the exploitable service footprint.
Impact	Unnecessary service exposure. IRC is a vector for C2 communication and data exfiltration in compromised environments.
Remediation	Remove the IRC daemon entirely if not a business requirement. Block IRC ports (6660–6669, 6697) at the network perimeter.

VULN-42 — Absence of Anti-CSRF Tokens — Application-Wide

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-352 / WASC-9
Detected By	ZAP (Systemic — Absence of Anti-CSRF Tokens, Medium flagged as Systemic)
Description	ZAP identified the absence of anti-CSRF tokens as a systemic issue across the web application. All state-changing requests can be forged by an attacker-controlled page loaded in a victim's authenticated browser session.
Impact	An attacker can perform unauthorised actions on behalf of an authenticated user, including account changes, data submission, and configuration modifications.
Remediation	Implement synchronised CSRF tokens on all state-changing forms and AJAX requests. Validate the Origin and Referer headers server-side as a secondary control.

VULN-43 — Apache Tomcat Manager — Default Credentials Accepted

Severity	Critical
CVSS Rating	9.8
CVE / CWE	CVE-2009-3548 / CWE-521
Detected By	Qualys VMDR (Basic + Credentialed Scans confirmed admin:admin and admin:password accepted by /manager/html)
Description	The Apache Tomcat Web Application Manager at /manager/html is accessible using default credentials. Qualys confirmed successful authentication using multiple default combinations. An authenticated Tomcat Manager session allows direct WAR file deployment.

Impact	Any attacker with network access to port 8080 can deploy an arbitrary WAR file and achieve remote code execution under the Tomcat service. This is a one-step path to full system compromise independent of all other vulnerabilities.
Remediation	Change all Tomcat Manager credentials immediately or remove the manager application if not required. Restrict /manager/* to trusted IPs via RemoteAddrValve in context.xml. Deploy a clean Tomcat installation with the manager disabled as part of the OS migration (VULN-14).

VULN-44 — TFTP Service — Unauthenticated File Access Including /etc/passwd

Severity	High
CVSS Rating	7.5
CVE / CWE	CVE-1999-0182 / CWE-284
Detected By	Qualys VMDR (Basic Scan: TFTP Daemon Theft of /etc/passwd confirmed; Credentialed Scan: TFTP Server Directory Traversal also confirmed on port 69/UDP)
Description	The TFTP service is running without authentication. Qualys confirmed two issues: unauthenticated retrieval of /etc/passwd via direct path request, and a directory traversal allowing access to arbitrary filesystem paths outside the TFTP working directory.
Impact	Remote attackers can obtain /etc/passwd to facilitate credential attacks against all services. Directory traversal extends this to arbitrary readable system files. No authentication is required.
Remediation	Disable the TFTP service immediately. If operationally required, restrict to a read-only chroot jail containing only approved files and limit access to specific trusted IPs. Block UDP port 69 at the perimeter.

VULN-45 — SMB Signing Not Required — NTLM Relay Attack Surface

Severity	Medium
CVSS Rating	5.3
CVE / CWE	CWE-300
Detected By	Nessus Basic Scan (Plugin 57608); Nessus Credentialed Scan (Plugin 57608 confirmed) — server does not require SMB message signing
Description	The SMB service does not require message signing. Without mandatory SMB signing, a network-adjacent attacker can perform NTLM relay attacks, forwarding captured authentication attempts to other services to authenticate as the victim.
Impact	A network-adjacent attacker can relay captured NTLM credentials to authenticate to other services. This enables lateral movement and is commonly chained with the Samba vulnerabilities in VULN-21.
Remediation	Enable mandatory SMB signing: set server signing = mandatory and client signing = mandatory in smb.conf. Enforce SMB signing from the outset on the replacement system during the OS migration (VULN-14).

VULN-46 — phpMyAdmin — Multiple XSS and CSRF Vulnerabilities (PMASA Advisories)

Severity	Medium
CVSS Rating	6.1
CVE / CWE	PMASA-2009-2, PMASA-2009-3, PMASA-2010-6, PMASA-2010-7, PMASA-2011-13
Detected By	Qualys VMDR Credentialed Scan confirmed: phpMyAdmin Backtrace XSS (PMASA-2010-6); Unspecified XSS (PMASA-2010-7); Multiple Vulnerabilities (PMASA-2009-2/3); Script Insertion (PMASA-2011-13)

Description	The installed phpMyAdmin version is affected by four published security advisories confirmed by Qualys: XSS via backtrace display, XSS via unspecified parameters, multiple script insertion, and CSRF/injection issues. phpMyAdmin provides direct database management access.
Impact	Exploitation allows XSS attacks against authenticated phpMyAdmin users. Given phpMyAdmin has direct access to the MySQL root account (VULN-09), session hijacking via any confirmed XSS instance grants complete database control.
Remediation	Upgrade phpMyAdmin to the latest stable release. If not deployable on this EOL OS, restrict access to phpMyAdmin to localhost or a trusted VPN subnet via Apache access controls. Deploy a current supported version as part of the OS migration (VULN-14).

VULN-47 — Apache Log4j 1.x — End-of-Life with Known Remote Code Execution (CVE-2019-17571)

Severity	High
CVSS Rating	8.1
CVE / CWE	CVE-2019-17571 / EOL August 2015
Detected By	Qualys VMDR Credentialed Scan: EOL/Obsolete Software: Apache Log4j 1.X Detected — no patches since August 2015; CVE-2019-17571 RCE via JMSAppender confirmed applicable. Distinct from Log4Shell (Log4j 2.x).
Description	Apache Log4j 1.x is installed and end-of-life since August 2015. CVE-2019-17571 is a critical RCE in Log4j 1.x via a crafted serialised object sent to a SocketServer listener. No security patches will be issued for this version.
Impact	An attacker who can reach a Log4j 1.x SocketServer listener can achieve unauthenticated remote code execution. The EOL status means any newly discovered vulnerabilities will receive no patches.
Remediation	Remove Log4j 1.x. Migrate dependent applications to Log4j 2.17.1 or later, or an alternative such as Logback. During the OS migration (VULN-14), audit all Java application dependencies for EOL libraries.

VULN-48 — .rhosts File and hosts.equiv Wildcard — Passwordless Remote Login Confirmed

Severity	High
CVSS Rating	7.5
CVE / CWE	CVE-1999-0651 / CWE-306
Detected By	Qualys VMDR Credentialed Scan: .rhosts File Present in User Home Directories confirmed; Wild Character (+) in /etc/hosts.equiv confirmed — allows any remote user on any host to log in without a password
Description	Qualys credentialed scanning confirmed .rhosts files in user home directories AND a wildcard (+) in /etc/hosts.equiv. The + entry means any user on any remote host can authenticate as the same username locally without a password, exploitable from any network-reachable host.
Impact	Any remote attacker can log into any account without a password by spoofing or connecting from any host. Combined with rlogin/rsh/rexec services (VULN-16), this creates an unrestricted passwordless access path to all user accounts.
Remediation	Remove all .rhosts files from all user home directories immediately. Delete or empty /etc/hosts.equiv removing the wildcard entry. Add file integrity monitoring to alert on any recreation of .rhosts files post-remediation.

VULN-49 — SMTP VRFY Command — Valid User Account Enumeration Confirmed

Severity	Medium

CVSS Rating	5.0
CVE / CWE	CVE-1999-0531 / CWE-203
Detected By	Qualys VMDR Credentialed Scan: Valid Logins/Aliases Guessed with SMTP VRFY Command confirmed; Greenbone OpenVAS: SMTP VRFY/EXPN active on port 25/tcp (VRFY root returns 252 2.0.0 root)
Description	The SMTP server responds to VRFY commands returning confirmation of valid user accounts. Qualys confirmed that valid account names can be enumerated. OpenVAS independently confirmed the VRFY and EXPN service is active, allowing an attacker to build an accurate list of valid local accounts.
Impact	An attacker can enumerate all valid local user accounts via unauthenticated SMTP VRFY queries, eliminating the username-guessing phase from brute-force attacks against every authenticated service on this host.
Remediation	Add disable_vrfy_command = yes to /etc/postfix/main.cf and reload. If SMTP is not required, remove the service entirely. Block port 25 at the perimeter firewall.

VULN-50 — Anonymous FTP Login Permitted

Severity	Medium
CVSS Rating	5.0
CVE / CWE	CVE-1999-0497 / CWE-284
Detected By	Qualys VMDR Basic Scan: Accessible Anonymous FTP Server confirmed; FTP users with Blank Password confirmed. Greenbone OpenVAS: Anonymous FTP Login Reporting NVT confirmed on port 21/tcp
Description	The FTP service accepts anonymous logins, allowing any unauthenticated user to connect and browse the FTP directory tree without credentials. Confirmed independently by Qualys and Greenbone OpenVAS. This is separate from the default-credentials finding in VULN-22.
Impact	Anonymous users can access and download files within FTP-accessible directories without authentication. Depending on permissions, anonymous upload may also be permitted, enabling delivery of malicious payloads.
Remediation	Set anonymous_enable=NO in /etc/vsftpd.conf. As vsftpd 2.3.4 is already a backdoored version (VULN-02), the service should be removed entirely and replaced with a clean verified version.

VULN-51 — ZAP: MD5 Crypt Password Hash Exposed in HTTP Response

Severity	High
CVSS Rating	7.5
CVE / CWE	CWE-200 / CWE-312
Detected By	ZAP Active Scan confirmed Hash Disclosure — MD5 Crypt (High) at http://10.0.2.4/mutillidae/index.php?page=source-viewer.php
Description	ZAP detected an MD5 Crypt password hash returned in an HTTP response via the Mutillidae source viewer component. The hash was present in the page output without authentication. MD5 Crypt hashes are rapidly crackable using modern GPU tools and rainbow tables.
Impact	Recovery of the plaintext password enables direct account compromise. If the password is reused across SSH, FTP, or database services, the impact extends to full host compromise across multiple services.
Remediation	Remove or restrict access to the Mutillidae source viewer. Audit all web application output for hash or credential leakage. Implement output filtering to block hash patterns in HTTP responses.

VULN-52 — SSL Anonymous Cipher Suites Supported — Unauthenticated TLS Possible

Severity	Medium
CVSS Rating	5.9
CVE / CWE	CWE-326
Detected By	Nessus Basic Scan (Plugin 31705 — SSL Anonymous Cipher Suites Supported); Nessus Credentialed Scan (Plugin 31705 confirmed)
Description	The TLS service supports anonymous cipher suites (NULL/anon key exchange), allowing encrypted connections with no server authentication whatsoever. This is more severe than a self-signed or expired certificate — no certificate is presented at all, making man-in-the-middle attacks fully transparent.
Impact	An attacker can silently intercept and modify all TLS traffic in real time with no certificate warning to the client. This affects all TLS-enabled services including PostgreSQL (VULN-10).
Remediation	Explicitly disable all anonymous and NULL cipher suites across all TLS services. Add !aNULL:!eNULL:!EXPORT to all OpenSSL cipher string configurations. Address as part of the broader TLS remediation in VULN-28.

VULN-53 — Vulnerable JavaScript Library — jQuery 1.3.2 XSS (CVE-2012-6708 / CVE-2011-4969)

Severity	Medium
CVSS Rating	6.1
CVE / CWE	CVE-2012-6708 / CVE-2011-4969
Detected By	ZAP: Vulnerable JS Library (Medium) at /mutillidae/javascript/ddsmoothmenu/jquery.min.js; Greenbone OpenVAS: jQuery < 1.9.0 CVE-2012-6708 and jQuery < 1.6.3 CVE-2011-4969 both confirmed — version 1.3.2 detected
Description	Mutillidae includes jQuery 1.3.2, confirmed by ZAP and OpenVAS. This version is affected by CVE-2012-6708 (XSS via HTML input with < characters in jQuery before 1.9.0) and CVE-2011-4969 (XSS via location.hash in jQuery before 1.6.3), independently confirmed by two separate tools.
Impact	Client-side script injection via vulnerable jQuery selector handling. Attackers influencing parameters processed by jQuery can inject and execute JavaScript in an authenticated user session.
Remediation	Upgrade jQuery to version 3.7.1 or later. Audit all web applications for third-party JavaScript library versions. Implement a Software Composition Analysis process to track and alert on vulnerable library versions.

VULN-54 — Directory Browsing Enabled — /dav/ and /doc/ Listings Exposed

Severity	Medium
CVSS Rating	5.3
CVE / CWE	CWE-548
Detected By	ZAP Active Scan: Directory Browsing (Medium) — 2 instances at http://10.0.2.4/dav/; Greenbone OpenVAS: /doc directory browsable NVT confirmed on port 80/tcp
Description	Directory listing is enabled on both the /dav/ WebDAV directory (ZAP confirmed 2 instances) and /doc/ (OpenVAS confirmed). Combined with the HTTP PUT capability in VULN-17, directory listing on /dav/ allows enumeration of all previously uploaded files.

Impact	Attackers can enumerate all files in exposed directories without authentication, identifying sensitive files, scripts, and backup content for targeted retrieval or exploitation.
Remediation	Set Options -Indexes in Apache configuration for all virtual host and directory blocks. Remove the Indexes option from /var/www/dav and /usr/share/doc directory configurations specifically.

VULN-55 — Session Cookies Missing HttpOnly and SameSite Flags (4 Confirmed Instances)

Severity	Low
CVSS Rating	3.7
CVE / CWE	CWE-1004 / CWE-1275
Detected By	ZAP Active Scan: Cookie No HttpOnly Flag (Low) — 4 confirmed instances; Cookie without SameSite Attribute (Low) — systemic across all session cookies
Description	ZAP confirmed 4 session cookies lack the HttpOnly flag and SameSite attributes are absent systemic across all cookies. The absence of HttpOnly makes session cookies accessible to JavaScript, enabling cookie theft via any of the 1,121 confirmed XSS instances in VULN-19. Absent SameSite independently enables CSRF paths.
Impact	Every confirmed XSS instance can be weaponised to steal active session cookies and hijack authenticated sessions. SameSite absence independently enables CSRF vectors beyond those requiring missing tokens.
Remediation	Set session.cookie_httponly = 1 and session.cookie_secure = 1 in php.ini. Add SameSite=Strict to all Set-Cookie headers. This is referenced in VULN-08 remediation but requires confirmation as a discrete deliverable.

VULN-56 — Private IP Address Disclosed in HTTP Responses (25 Instances)

Severity	Low
CVSS Rating	3.1
CVE / CWE	CWE-200
Detected By	ZAP Active Scan: Private IP Disclosure (Low) — 25 confirmed instances across web application HTTP responses
Description	ZAP detected 25 instances where the web application returns internal RFC 1918 IP addresses in HTTP response bodies or headers. Internal IP disclosure assists attackers in network reconnaissance, confirming topology and identifying further targets on the same subnet.
Impact	Disclosure of internal addressing enables accurate network reconnaissance and assists in identifying lateral movement targets. In a production financial environment this would directly aid post-exploitation planning.
Remediation	Audit all application code and web server configurations to remove internal IP references from user-facing output. Configure Apache to suppress error pages that include internal addressing. Suppress Server header version and internal paths from all error responses.

VULN-57 — ProFTPD 1.3.3c Backdoor — Unauthenticated Root Shell (Port 2121/tcp)

Severity	Critical
CVSS Rating	10.0 (CVSS v2.0)
CVE / CWE	CVE-2011-2523 / CWE-912 (Hidden Functionality)
Detected By	Greenbone OpenVAS (CVE-2011-2523 QoD 99%); Qualys VMDR Basic + Credentialed Scans (ProFTPD 1.3.1 confirmed on port 2121/tcp; proftpd:x:113 in /etc/passwd)

Description	The ProFTPD 1.3.3c distribution package was trojanised by an attacker before official release. A backdoor activates when any username containing :) is sent to the FTP service on port 2121/tcp. Upon trigger, a root shell spawns on port 6200/tcp accessible without further authentication. ProFTPD 1.3.1 is confirmed listening on port 2121/tcp. This is the fourth confirmed active backdoor on this host alongside VULN-01 (Ingreslock), VULN-02 (vsftpd), and VULN-03 (UnrealIRCd).
Impact	Any unauthenticated attacker with network access to port 2121/tcp obtains a root shell within seconds. All four active backdoors combined ensure complete and persistent compromise of the host regardless of other controls in place.
Remediation	Remove ProFTPD 1.3.1 immediately and replace with ProFTPD 1.3.8+. Block port 2121/tcp and port 6200/tcp at the network perimeter. Compare all FTP binaries against known-good checksums. Treat the host as fully compromised and conduct a complete re-image as part of the OS migration (VULN-14).

VULN-58 — Apache Tomcat Manager — Default Credentials on Port 8180 (tomcat:tomcat)

Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2009-3548 / CWE-521 (Weak Credentials)
Detected By	Qualys VMDR Basic Scan (port 8180/tcp; Tomcat Manager confirmed accessible; tomcat:tomcat authenticated successfully; QID 86857)
Description	A second Apache Tomcat instance runs on port 8180/tcp with its Web Application Manager accessible at /manager/html. Qualys confirmed successful authentication using tomcat:tomcat. This is completely independent from the instance documented in VULN-43 (port 8080). The VULN-43 remediation guidance references only port 8080, meaning this endpoint would remain fully exploitable even after VULN-43 is fully remediated.
Impact	An attacker with network access to port 8180/tcp can deploy an arbitrary WAR file through the Manager interface and achieve remote code execution under the Tomcat service account in minutes. This is a complete one-step RCE path that exists independently of all other vulnerabilities and is likely to be overlooked given the VULN-43 remediation gap.
Remediation	Change or disable all Tomcat Manager credentials on port 8180/tcp immediately. Apply the same RemoteAddrValve IP restrictions recommended in VULN-43. Shut down port 8180/tcp entirely if it serves no operational purpose. During the OS migration (VULN-14), audit all running Tomcat instances across all non-standard ports before decommissioning.

VULN-59 — Samba Out-of-Bounds Heap R/W RCE via vfs_fruit (CVE-2021-44142)

Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CVE-2021-44142 / CWE-787 (Out-of-Bounds Write)
Detected By	Qualys VMDR Basic + Credentialed Scans (CVE-2021-44142; Samba 3.0.20-Debian confirmed; all Samba < 4.13.17 affected)
Description	All Samba versions prior to 4.13.17 are vulnerable to an out-of-bounds heap read/write in the vfs_fruit VFS module. Processing Extended Attributes in SMB2 IOCTL operations triggers an integer overflow allowing arbitrary heap memory read/write. Samba 3.0.20 is far below the fixed version. Combined with five other Samba RCE paths (VULN-21, VULN-61, VULN-69, VULN-70, VULN-71, VULN-72), the Samba service represents the most richly exploitable attack surface after the active backdoors.
Impact	Remote unauthenticated attackers can execute arbitrary code as the root user via crafted SMB2 requests. Six distinct Samba RCE CVEs are confirmed on this host;

	CVE-2021-44142 is the most recently disclosed and most likely to have active weaponised exploit tooling.
Remediation	Upgrade Samba to 4.13.17 or later (achievable only through the OS migration per VULN-14). As an immediate measure, restrict SMB access to trusted IP addresses at the firewall and disable vfs_fruit in smb.conf if not required.

VULN-60 — TikiWiki Exposed Installer — /tikiwiki/tiki-install.php Accessible

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2006-4683 / CWE-552 (Files Accessible to External Parties)
Detected By	Greenbone OpenVAS (Cleartext Transmission NVT QoD 80%; /tikiwiki/tiki-install.php confirmed accessible; password form over HTTP)
Description	The TikiWiki installer at /tikiwiki/tiki-install.php is publicly accessible without authentication. OpenVAS confirmed the installer is reachable and that its password form transmits credentials over unencrypted HTTP. An accessible installer allows attackers to re-initialise the application, overwrite database configuration, and obtain administrative access. TikiWiki joins DVWA, Mutillidae, TWiki, and phpMyAdmin as web applications on this host with significant attack surface.
Impact	Unauthenticated attackers can use the accessible installer to reset TikiWiki, gain administrative access, and achieve PHP code execution through TikiWiki administrative functions. Credentials entered in the installer are interceptable via network monitoring given the HTTP cleartext issue (VULN-83).
Remediation	Delete or restrict tiki-install.php immediately. Enforce HTTPS across all web applications. Restrict /tikiwiki/ to trusted IP addresses. Audit all web application installer scripts and administrative endpoints accessible without authentication.

VULN-61 — Samba NMBD Heap Overflow — NDR Parsing RCE (CVE-2007-2446)

Severity	High
CVSS Rating	7.8 (CVSS v2.0)
CVE / CWE	CVE-2007-2446 / CWE-122 (Heap-Based Buffer Overflow)
Detected By	Qualys VMDR Basic + Credentialed Scans (CVE-2007-2446; Samba 3.0.20 confirmed; NDR heap overflow in MS-RPC parsing)
Description	A heap overflow exists in Samba 3.0.20 due to bugs in NDR (Network Data Representation) parsing used to decode MS-RPC requests. The nmbd daemon does not properly validate RPC request data, allowing a crafted request to overflow a heap buffer. This is a separate and distinct vulnerability from CVE-2007-2447 documented in VULN-21, exploiting a different code path.
Impact	Remote unauthenticated attackers can execute arbitrary code as the Samba service account via crafted MS-RPC requests, potentially escalating to root given the EOL kernel. This is the second distinct Samba RCE path alongside CVE-2007-2447.
Remediation	Upgrade Samba beyond 3.0.25rc3 (requires OS migration per VULN-14). Restrict SMB/CIFS access to trusted IP addresses at the firewall. Add to VULN-21 remediation tracking.

VULN-62 — UnrealIRCd Certificate Fingerprint Spoofing (CVE-2016-7144)

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CVE-2016-7144 / CWE-295 (Improper Certificate Validation)

Detected By	Greenbone OpenVAS (UnrealIRCd Authentication Spoofing NVT; separate from backdoor NVT; version 3.2.8.1 confirmed; fixed in 3.2.10.7)
Description	UnrealIRCd 3.2.8.1 contains a flaw in the m_authenticate function in modules/m_sasl.c that allows attackers to spoof certificate fingerprints. An attacker can impersonate any IRC user by presenting a crafted certificate during SASL authentication. This is completely separate from the backdoor in VULN-03, with a different CVE and different remediation requirement.
Impact	Authenticated attackers or IRC service users can impersonate any IRC user account including administrators. If IRC is used for operational communication or IRC bots have elevated trust, this enables privilege escalation within the IRC service.
Remediation	Upgrade UnrealIRCd to 3.2.10.7 or 4.0.6+ as documented in VULN-03. Removing the backdoor alone does not fix this authentication spoofing. Verify the upgrade version specifically reaches 3.2.10.7 which patches both CVE-2010-2075 and CVE-2016-7144.

VULN-63 — phpinfo.php Unauthenticated Access — Confirmed RCE Via EasyPHP (QoD 99%)

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CWE-94 (Code Injection) / CWE-200 (Information Exposure)
Detected By	Greenbone OpenVAS (EasyPHP Webserver <= 12.1 Multiple Vulnerabilities NVT QoD 99%; phpinfo() execution confirmed at /phpinfo.php)
Description	/phpinfo.php is publicly accessible without authentication and returns full PHP configuration output. OpenVAS triggered the EasyPHP NVT at QoD 99%, confirming active exploitation: the accessible phpinfo() output enables PHP code injection in EasyPHP-configured contexts. The exposed page reveals internal file paths (/etc/php5/cgi), PHP configuration directives, loaded modules, and environment variables directly assisting further attacks.
Impact	Not merely informational: OpenVAS scored it High/7.5 based on confirmed code injection potential. Combined with PHP CGI RCE (VULN-07) and source disclosure (VULN-66), three independently confirmed PHP code execution paths exist. The phpinfo() exposure directly accelerates exploitation of each.
Remediation	Delete or restrict /phpinfo.php immediately. Set expose_php = Off in php.ini. Remove all phpinfo() calls from production applications. Review all .php files accessible from the web root for diagnostic functions.

VULN-64 — phpMyAdmin /scripts/setup.php Remote Code Injection (CVE-2009-1151)

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2009-1151 / CWE-94 (Code Injection)
Detected By	Qualys VMDR Basic Scan (CVE-2009-1151; phpMyAdmin <= 3.1.3.1 affected; Metasploit module: exploit/unix/webapp/phpmyadmin_config; Core Security exploit confirmed)
Description	phpMyAdmin versions before 3.1.3.1 fail to sanitise configuration parameters during setup at /scripts/setup.php. This allows an unauthenticated attacker to inject arbitrary PHP code into the configuration file. The injected code executes on subsequent requests. A public Metasploit module and multiple Exploit-DB entries exist for immediate exploitation.
Impact	Unauthenticated attackers achieve arbitrary PHP code execution in a single HTTP request by injecting a PHP webshell into the configuration file. This is distinct from and more severe than the XSS in VULN-46. With a live Metasploit module, exploitation requires no specialised knowledge.

Remediation	Upgrade phpMyAdmin to the latest stable release (5.x). Delete or block access to /scripts/setup.php if upgrade is not immediately possible. Restrict phpMyAdmin to trusted IP addresses. This is an additional remediation requirement on top of VULN-46.

VULN-65 — TWiki 'rev' Parameter Shell Metacharacter RCE (CVE-2005-2877)

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2005-2877 / CWE-78 (OS Command Injection)
Detected By	Qualys VMDR Basic Scan (CVE-2005-2877; Metasploit module: exploit/unix/webapp/twiki_history; TWiki 01.Feb.2003 installed)
Description	The TWikiUsers script uses backtick shell metacharacters to construct revision control commands. The rev parameter is not sanitised before passing to the shell, allowing arbitrary OS command execution. This is separate from CVE-2008-5305 in VULN-18, exploiting TWikiUsers rather than SEARCH/INCLUDE. Both have independent Metasploit modules targeting completely different code paths.
Impact	Remote unauthenticated attackers execute arbitrary OS commands as the web server user via a single crafted GET request to /twiki/bin/view/Main/TWikiUsers?rev=[payload]. Combined with the EOL kernel, this provides a path to root.
Remediation	Upgrade TWiki to 4.2.4+ as documented in VULN-18. This CVE requires a patch distinct from CVE-2008-5305; verify both are addressed in the upgraded version. Restrict /twiki/ to authenticated users only.

VULN-66 — PHP CGI Source Code Disclosure via -s Flag — 9 ZAP Confirmed Instances

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2012-1823 (disclosure variant) / CWE-540 (Source Code in Public Accessible File)
Detected By	ZAP Active Scan (Source Code Disclosure - CVE-2012-1823 alert; 9 confirmed instances; full PHP source returned at /dvwa/?-s and /dvwa/login.php?-s)
Description	When PHP runs in CGI mode, appending ?-s to a URL returns raw PHP source instead of executing it. ZAP confirmed 9 instances including full source of /dvwa/index.php and /dvwa/login.php, exposing database query logic, password hashing (MD5), internal paths (/var/www/mutillidae/), and all application business logic. This is a companion to the RCE in VULN-07 using the same CVE-2012-1823 root cause but exploiting the read path.
Impact	Attackers retrieve complete PHP source of any accessible .php file by appending ?-s. This reveals database schemas, authentication logic, hardcoded credentials, internal file paths, and all application secrets, directly assisting SQL injection and authentication bypass.
Remediation	Fix is identical to VULN-07: upgrade PHP to a supported version and disable PHP CGI mode. Set cgi.force_redirect=1 as an immediate mitigation. Add this source disclosure path to VULN-07 remediation tracking.

VULN-67 — Samba RC4/HMAC Weak Hash Downgrade (CVE-2022-45141)

Severity	High
CVSS Rating	8.1 (CVSS v3.1)
CVE / CWE	CVE-2022-45141 / CWE-327 (Use of Broken or Risky Cryptographic Algorithm)

Detected By	Qualys VMDR Basic Scan (CVE-2022-45141; Samba 3.0.20 confirmed affected; all Samba < 4.15.13 vulnerable)
Description	Samba versions prior to 4.15.13 can be forced to issue rc4-hmac encrypted Kerberos tickets when operating as an AD Domain Controller using Heimdal KDC. Attackers coerce use of this weak RC4 cipher, making captured Kerberos traffic susceptible to offline cracking. Samba 3.0.20 is far below the fixed version threshold.
Impact	Attackers who intercept Kerberos traffic (possible given the cleartext transmission vulnerabilities on this host) can capture RC4-encrypted tickets and crack them offline, recovering user credentials without active server attack.
Remediation	Upgrade Samba to 4.15.13+ (requires OS migration per VULN-14). Restrict Kerberos traffic to trusted segments and disable NTLM/RC4 authentication methods in smb.conf where possible.

VULN-68 — NFS-Utils Xlog Remote Buffer Overflow via mountd (CVE-2003-0252)

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2003-0252 / CWE-193 (Off-by-One Error)
Detected By	Qualys VMDR Basic Scan (QID 68521; CVE-2003-0252; Severity 5; NFS service confirmed on host; RHSA-2003:207)
Description	The xlog() function in nfs-utils has an off-by-one boundary condition in xlog.c. When a buffer of 1023+ bytes is supplied via RPC requests to mountd, exactly one byte of memory beyond the allocated buffer is overwritten with attacker-controlled data. This is exploitable via crafted RPC mount requests. NFS world-readable shares are confirmed in VULN-20.
Impact	Remote unauthenticated attackers with access to port 2049/tcp and the RPC portmapper can exploit this off-by-one overflow via crafted mountd requests, potentially achieving arbitrary code execution as the NFS daemon user.
Remediation	Apply nfs-utils patch from RHSA-2003:207. On Ubuntu 8.04 EOL this requires the OS migration (VULN-14). Immediately restrict NFS port access to trusted IP addresses and disable mountd if NFS is not operationally required.

VULN-69 — Samba receive_smb_raw() Heap Buffer Overflow RCE (CVE-2008-1105)

Severity	High
CVSS Rating	7.9 (CVSS v2.0)
CVE / CWE	CVE-2008-1105 / CWE-122 (Heap-Based Buffer Overflow)
Detected By	Qualys VMDR Basic + Credentialed Scans (CVE-2008-1105; Samba 3.0.0-3.0.29 affected; 3.0.20 confirmed; Exploit-DB PoC 5712)
Description	The receive_smb_raw() function in util/sock.c in Samba 3.0.0 through 3.0.29 contains a heap buffer overflow. Remote attackers send specially crafted SMB packets that overflow the receive buffer, enabling arbitrary code execution. Samba 3.0.20 is within the confirmed affected range. A public PoC is available on Exploit-DB (ID 5712).
Impact	Remote unauthenticated attackers execute arbitrary code as the Samba service account via crafted SMB packets on port 445/tcp. This is the third distinct heap overflow in Samba 3.0.20 alongside CVE-2007-2446 (VULN-61) and CVE-2012-1182 (VULN-71).
Remediation	Upgrade Samba beyond 3.0.29 (requires OS migration per VULN-14). Restrict port 445/tcp to trusted IP addresses at the firewall. Add to VULN-21 remediation tracking.

VULN-70 — Samba chain_reply() Memory Corruption (CVE-2010-2063)

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2010-2063 / CWE-119 (Buffer Errors)
Detected By	Qualys VMDR Basic Scan (CVE-2010-2063; Samba before 3.4.8 and 3.5.x before 3.5.2 affected; 3.0.20 confirmed; Metasploit module available Exploit-DB 16860)
Description	The chain_reply() function in process.c in smbd allows remote attackers to cause denial of service and potentially execute arbitrary code via an invalid chained SMB request. The reply_sesssetup_and_X_spnego() function in sesssetup.c is also affected. Samba 3.0.20 is below all fixed versions.
Impact	Remote unauthenticated attackers can crash smbd (DoS) or potentially achieve code execution via malformed chained SMB requests. Even where RCE is not reliably achieved, DoS capability disrupts file sharing services.
Remediation	Upgrade Samba beyond 3.4.8 (requires OS migration per VULN-14). Implement rate limiting on SMB connections and restrict port 445/tcp to trusted IP addresses immediately.

VULN-71 — Samba MS-RPC Code Generator Heap Overflow — Root RCE (CVE-2012-1182)

Severity	High
CVSS Rating	8.3 (CVSS v2.0)
CVE / CWE	CVE-2012-1182 / CWE-122 (Heap-Based Buffer Overflow)
Detected By	Qualys VMDR Basic Scan (CVE-2012-1182; all Samba <= 3.6.3 affected; root code execution confirmed by vendor advisory; fixed in 3.4.16/3.5.14/3.6.4)
Description	The Samba RPC code generator contained an error that generated code with a heap overflow flaw, present in all Samba versions through 3.6.3. Exploitable via crafted RPC requests. The Samba security advisory explicitly states successful exploitation allows attackers to execute arbitrary code as the root user. Samba 3.0.20 is confirmed affected.
Impact	Remote unauthenticated attackers execute arbitrary code as root via crafted RPC requests. Vendor-confirmed root-level execution makes this the most severe of the six Samba RCE paths and the only one explicitly confirmed as root in vendor documentation.
Remediation	Upgrade Samba to 3.4.16, 3.5.14, or 3.6.4+ (requires OS migration per VULN-14). Add to VULN-21 remediation tracking as this CVE is not currently documented there.

VULN-72 — Samba send_mailslot() Heap Overflow (CVE-2007-6015)

Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2007-6015 / CWE-122 (Heap-Based Buffer Overflow)
Detected By	Qualys VMDR Basic Scan (CVE-2007-6015; Samba < 3.0.28 affected; 3.0.20 confirmed in range)
Description	A heap overflow in send_mailslot() in Samba versions prior to 3.0.28 allows remote attackers to execute arbitrary code via a long GETDC mailslot request. Samba 3.0.20 is confirmed within the affected range. This is the fifth distinct buffer overflow in the Samba installation (alongside CVE-2007-2446, CVE-2008-1105, CVE-2010-2063, and CVE-2012-1182).
Impact	Remote unauthenticated attackers execute arbitrary code via crafted GETDC mailslot requests to NMBD. The depth of Samba vulnerabilities (six distinct RCE CVEs) means the attack surface remains critically wide even with individual mitigations.
Remediation	Upgrade Samba beyond 3.0.28 (requires OS migration per VULN-14). Disable nmbd if NetBIOS mailslot functionality is not required. Add to VULN-21 remediation tracking.

VULN-73 — ProFTPD mod_sql SQL Injection and Buffer Overflow (CVE-2009-0542/CVE-2009-0543)	
Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2009-0542 / CVE-2009-0543 / CWE-89 (SQL Injection)
Detected By	Qualys VMDR Basic + Credentialed Scans (CVE-2009-0542; ProFTPD 1.3.1 < fixed 1.3.2; port 2121/tcp confirmed)
Description	ProFTPD 1.3.1 is vulnerable to SQL injection in the mod_sql module (CVE-2009-0542). FTP usernames are not sanitised before use in SQL queries, allowing auth bypass and arbitrary SQL injection. CVE-2009-0543 is a related buffer overflow via sql_escape_string when processing character encoding conversion. These vulnerabilities are independent from the backdoor in VULN-57.
Impact	Remote unauthenticated attackers can bypass FTP authentication and potentially achieve code execution via the buffer overflow. These CVEs provide additional exploitation paths even if the VULN-57 backdoor is removed.
Remediation	Replace ProFTPD 1.3.1 with ProFTPD 1.3.8+ as part of the OS migration (VULN-14). This is the same action as VULN-57 - both require replacing the ProFTPD installation entirely.

VULN-74 — ProFTPD Response Pool Use-After-Free and SFTP Module Vulnerabilities (CVE-2011-4130)	
Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2011-4130 / CWE-416 (Use After Free)
Detected By	Qualys VMDR Basic Scan (CVE-2011-4130 Sev 4; ProFTPD Response Pool Use-After-Free; ProFTPD 1.3.1 on port 2121/tcp confirmed)
Description	ProFTPD versions before 1.3.3g/1.3.4 contain a use-after-free in response pool handling. When a Response object is freed and subsequently referenced, an attacker can potentially redirect execution to attacker-controlled memory. ProFTPD 1.3.1 predates fixes for both the UAF and multiple mod_sftp SFTP module vulnerabilities.
Impact	Remote attackers can trigger the use-after-free to potentially achieve arbitrary code execution. Combined with the backdoor (VULN-57) and SQL injection (VULN-73), the ProFTPD service has at least three independently exploitable vulnerability classes.
Remediation	Replace ProFTPD 1.3.1 with version 1.3.8+ as part of the OS migration (VULN-14). This consolidated remediation covers VULN-57, VULN-73, and VULN-74 simultaneously.

VULN-75 — PHP CGI Post-Patch Bypass Variants (CVE-2012-2335/CVE-2012-2336)	
Severity	High
CVSS Rating	7.5 (CVSS v2.0)
CVE / CWE	CVE-2012-2335 / CVE-2012-2336 / CWE-78 (OS Command Injection)
Detected By	Qualys VMDR Basic + Credentialed Scans (CVE-2012-2335/2336; PHP 5.2.4 confirmed affected)
Description	CVE-2012-2335 and CVE-2012-2336 are bypass variants of the PHP CGI argument injection (CVE-2012-1823, VULN-07). CVE-2012-2335 bypasses the CVE-2012-1823 fix via alternative query string manipulation still passing arguments to the PHP binary. CVE-2012-2336 achieves PHP source disclosure through a related bypass. Partial patching of CVE-2012-1823 alone does not fully close the attack surface.

Impact	Attackers who find CVE-2012-1823 partially mitigated can still use these bypass variants to achieve argument injection and source code disclosure. All three CVEs (VULN-07 plus VULN-75) must be remediated together.
Remediation	Fix is identical to VULN-07: upgrade PHP to 8.1+ and disable PHP CGI mode entirely. No patch applied to PHP 5.2.4 will be complete without a full version upgrade.

VULN-76 — Apache Range Header Denial of Service — Apache Killer (CVE-2011-3192)

Severity	High
CVSS Rating	7.8 (CVSS v2.0)
CVE / CWE	CVE-2011-3192 / CWE-400 (Uncontrolled Resource Consumption)
Detected By	Qualys VMDR Basic Scan (CVE-2011-3192; Apache 2.2.8 < fixed 2.2.21; named Apache Killer exploit publicly available)
Description	Apache HTTP Server through 2.2.20 processes HTTP requests with many overlapping Range header values by consuming all available memory and CPU on the server. The Apache Killer exploit demonstrates that a single request can take down the web server. Apache 2.2.8 is confirmed installed and is below the fixed version.
Impact	A single unauthenticated HTTP request exhausts all server memory and CPU, taking down all web applications on port 80/tcp (DVWA, Mutillidae, TWiki, phpMyAdmin, TikiWiki). This is a trivial, unskilled denial of service attack requiring no target-specific knowledge.
Remediation	Upgrade Apache to 2.2.21+ (requires OS migration per VULN-14). Immediately add to httpd.conf: RangeOverlaps 0 and RequestRange 3 200, or use mod_headers to strip Range headers from incoming requests.

VULN-77 — Apache HTTP Server 2.2.x End-of-Life — No Security Updates Since July 2017

Severity	High
CVSS Rating	8.0 (CVSS v3.0)
CVE / CWE	CWE-1104 (Use of Unmaintained Third Party Components)
Detected By	Qualys VMDR Basic Scan (Severity 5; Apache HTTP Server 2.2.x EOL confirmed; EOL date: July 2017; Apache 2.2.8 on port 80/tcp)
Description	Apache HTTP Server 2.2.x reached end-of-life in July 2017. The installed version 2.2.8 was released in January 2008, now nearly 17 years ago. All CVEs affecting 2.2.x discovered since July 2017 are permanently unpatched. The report documents Tomcat EOL as Critical (VULN-15) but omits a dedicated entry for Apache HTTP Server EOL, creating an inconsistency in EOL coverage framework.
Impact	All CVEs affecting Apache 2.2.x since July 2017, including OptionsBleed (VULN-86), Apache Killer (VULN-76), and numerous others documented in this report, are permanently unpatched. Every new Apache HTTP Server vulnerability reported in public databases is applicable and exploitable indefinitely.
Remediation	Migrate to Apache HTTP Server 2.4.x as part of the OS migration (VULN-14). This is the same foundational remediation as VULN-15 (Tomcat EOL) and requires complete infrastructure replacement.

VULN-78 — Java RMI Registry Exposed — Unauthenticated Remote Method Invocation

Severity	Medium
CVSS Rating	6.5 (CVSS v3.0)
CVE / CWE	CWE-749 (Exposed Dangerous Method) / CWE-306 (Missing Authentication)
Detected By	Nessus Basic + Credentialed Scans (Plugin 22227 - RMI Registry Detection; RMI registry confirmed listening)

Description	Nessus detected an exposed Java RMI (Remote Method Invocation) registry without authentication controls. Remote attackers can enumerate registered remote objects and invoke methods on them. On Metasploitable 2, the exposed RMI registry is exploitable via Metasploit module exploit/multi/misc/java_rmi_server through Java deserialization gadget chains.
Impact	Unauthenticated remote attackers can enumerate the RMI registry, identify registered objects, and invoke methods including those executing OS commands via Java deserialization. This provides an additional RCE path independent of all other vulnerabilities.
Remediation	Disable the Java RMI registry service if not operationally required. If required, implement RMI over SSL with mutual authentication and restrict the RMI port at the network perimeter firewall.

VULN-79 — SSL/TLS Renegotiation CPU Exhaustion DoS (CVE-2011-1473/CVE-2011-5094)

Severity	Medium
CVSS Rating	4.3 (CVSS v2.0)
CVE / CWE	CVE-2011-1473 / CVE-2011-5094 / CWE-400 (Uncontrolled Resource Consumption)
Detected By	Greenbone OpenVAS (SSL/TLS Renegotiation DoS NVT QoD 70%; 10 successful renegotiations induced on TLSv1.0 service)
Description	The TLS service does not restrict client-initiated renegotiation. OpenVAS confirmed this by inducing 10 SSL/TLS handshake renegotiations within a single established connection. Repeated renegotiation consumes disproportionate server CPU, leading to denial of service.
Impact	A single attacker connection can generate sustained high CPU load, degrading service availability for legitimate users. Combined with other DoS vectors (VULN-76, VULN-87), this compounds availability risk.
Remediation	Disable client-initiated TLS renegotiation by adding SSL_OP_NO_RENEGOTIATION to the SSL context flags. This configuration change can be applied without an OS upgrade, making it one of the few mitigations achievable on the current platform.

VULN-80 — TWiki Cross-Site Request Forgery (CVE-2009-4898)

Severity	Medium
CVSS Rating	6.1 (CVSS v3.0)
CVE / CWE	CVE-2009-4898 / CWE-352 (Cross-Site Request Forgery)
Detected By	Greenbone OpenVAS (TWiki CSRF NVT QoD 80%; installed version 01.Feb.2003 confirmed; requires upgrade to 4.3.2)
Description	TWiki prior to 4.3.2 is vulnerable to CSRF. An attacker tricks an authenticated TWiki administrator into visiting a page with a malicious POST request. The request is processed by TWiki as if made by the administrator, allowing arbitrary administrative actions including account creation, content modification, and permission changes.
Impact	Attackers who lure authenticated TWiki administrators into visiting a malicious page can perform any administrative action without their knowledge, including creating backdoor accounts and leveraging TWiki command execution capabilities from VULN-18 and VULN-65.
Remediation	Upgrade TWiki to 4.3.2+ as documented in VULN-18. This CSRF fix is included in the same upgrade. Verify the upgraded version includes the token-based CSRF fix (SecurityAuditTokenBasedCsrfFix).

VULN-81 — Mutillidae Local File Inclusion — Active /etc/passwd Read Confirmed (QoD 99%)

Severity	Medium

CVSS Rating	5.0 (CVSS v2.0)
CVE / CWE	CWE-22 (Path Traversal) / CWE-73 (External Control of File Name)
Detected By	Greenbone OpenVAS (awiki LFI NVT QoD 99%; /etc/passwd returned at /mutillidae/index.php?page=/etc/passwd; null-byte traversal confirmed)
Description	Greenbone OpenVAS confirmed at QoD 99% that Mutillidae's page parameter accepts arbitrary file paths and null-byte-terminated traversal sequences, returning /etc/passwd in both cases. Two techniques confirmed: direct path injection (?page=/etc/passwd) and null-byte traversal (?page=../../../etc/passwd%00). While Mutillidae is intentionally vulnerable, it is exposed on the public-facing port 80/tcp.
Impact	Active LFI allows unauthenticated attackers to read arbitrary server-side files including /etc/passwd, configuration files with database credentials, SSL private keys, and application source code.
Remediation	Remove all intentionally vulnerable web applications (DVWA, Mutillidae, TWiki, phpMyAdmin) from the production interface. Restrict them to an isolated training network. They must not be exposed on any internet-facing or production network interface.

VULN-82 — phpMyAdmin error.php BBcode XSS (CVE-2010-4480) — QoD 99% Confirmed

Severity	Medium
CVSS Rating	4.3 (CVSS v2.0)
CVE / CWE	CVE-2010-4480 / CWE-79 (Cross-Site Scripting)
Detected By	Greenbone OpenVAS (phpMyAdmin error.php XSS NVT QoD 99%; CVE-2010-4480; phpMyAdmin <= 3.3.8.1 confirmed)
Description	phpMyAdmin 3.3.8.1 and prior are vulnerable to stored XSS in error.php via BBcode tags containing @ characters. Greenbone confirmed this at QoD 99%. Injected JavaScript executes in the context of any authenticated database administrator who encounters the error page.
Impact	Attackers inject persistent JavaScript into phpMyAdmin error pages that executes in any database administrator session. Since phpMyAdmin provides direct MySQL administration, XSS exploitation leads to complete database compromise including credential theft.
Remediation	Upgrade phpMyAdmin to the current stable release (5.x) as part of VULN-46 remediation. This CVE should be explicitly verified as addressed in the upgrade target version.

VULN-83 — Cleartext Credential Transmission — Four Applications Confirmed Over HTTP

Severity	Medium
CVSS Rating	4.3 (CVSS v2.0)
CVE / CWE	CWE-319 (Cleartext Transmission of Sensitive Information)
Detected By	Greenbone OpenVAS (Cleartext Transmission NVT QoD 80%; password fields confirmed over HTTP: /dvwa/login.php:password, /phpMyAdmin/:pma_password, /tikiwiki/tiki-install.php:pass, /twiki/bin/view/TWiki/TWikiUserAuthentication:oldpassword)
Description	OpenVAS confirmed at QoD 80% that four web applications transmit passwords over unencrypted HTTP: DVWA (login), phpMyAdmin (database admin), TikiWiki (installer), and TWiki (authentication). Any attacker with network adjacency can intercept these credentials with passive packet capture.
Impact	Network-adjacent attackers intercept database administrator credentials, application login credentials, and administrative passwords using any packet capture tool without triggering any application-level alert. Captured credentials likely reuse passwords applied elsewhere.

Remediation	Deploy TLS/HTTPS across all web applications and enforce HTTPS-only via HSTS headers. Generate and install a valid SSL certificate. Configure Apache to redirect all HTTP to HTTPS. This systemic fix addresses all four applications simultaneously.

VULN-84 — Vim < 9.1.2132 Heap Buffer Overflow (GHSA-5w93-4g67-mm43)

Severity	Medium
CVSS Rating	6.6 (CVSS v3.1)
CVE / CWE	GHSA-5w93-4g67-mm43 / CWE-122 (Heap-Based Buffer Overflow)
Detected By	Nessus Credentialed Scan (Plugin 298656; Vim confirmed installed; version below 9.1.2132; VPR 4.4)
Description	Nessus confirmed Vim is installed below the fixed version 9.1.2132. The heap buffer overflow is triggered by processing malicious file content. In post-exploitation scenarios or multi-user systems, an attacker can plant a malicious file for a privileged user to open, achieving privilege escalation.
Impact	In post-exploitation scenarios, attackers plant malicious files and wait for privileged users to open them in Vim, achieving privilege escalation. A vulnerable Vim version combined with misconfigured sudo rules can provide a direct local privilege escalation path.
Remediation	Upgrade Vim to 9.1.2132+ (requires OS migration per VULN-14). Remove Vim if not required, or replace with a less feature-rich editor lacking the vulnerable scripting functionality.

VULN-85 — PostgreSQL PassTheHash — MD5 Authentication Protocol Weakness

Severity	Medium
CVSS Rating	6.5 (CVSS v3.0)
CVE / CWE	CWE-916 (Use of Password Hash with Insufficient Computational Effort)
Detected By	Qualys VMDR Credentialed Scan (QID 373102; PostgreSQL < v10 affected; MD5 hash reuse confirmed as protocol weakness)
Description	PostgreSQL versions prior to v10 use MD5-hashed passwords in a protocol allowing PassTheHash attacks. An attacker obtaining MD5 hashes from pg_shadow (possible via SQL injection in VULN-18 or default credentials in VULN-10) can authenticate directly using the hash without knowing the plaintext. Changing passwords does not invalidate captured hashes.
Impact	Attackers who obtain PostgreSQL password hashes can authenticate to the database indefinitely using those hashes, even after password rotation. This makes the PostgreSQL installation permanently vulnerable to re-authentication attacks until the authentication method is upgraded.
Remediation	Upgrade PostgreSQL to v10+ and configure SCRAM-SHA-256 authentication in pg_hba.conf (requires OS migration per VULN-14). Ensure pg_shadow is not readable by application users and that no SQL injection vulnerabilities provide hash access.

VULN-86 — Apache OptionsBleed — Memory Disclosure via OPTIONS Method (CVE-2017-9798)

Severity	Medium
CVSS Rating	5.9 (CVSS v3.0)
CVE / CWE	CVE-2017-9798 / CWE-200 (Information Exposure)
Detected By	Qualys VMDR Credentialed Scan (CVE-2017-9798; Apache 2.2.8 confirmed affected; Qualys Severity 4)

Description	Apache HTTP Server prior to 2.4.28 (and 2.2.x prior to 2.2.35) has a use-after-free in Options directive processing. When processing OPTIONS requests, Apache may return Allow headers containing stale heap memory, potentially leaking sensitive data such as server secrets, private key material, or authentication tokens. Apache 2.2.8 predates all fixes.
Impact	Remote attackers who can issue OPTIONS requests may receive server heap contents in the Allow response header. Depending on what is in heap memory, this could expose partial private key material, authentication tokens, or database passwords.
Remediation	Upgrade Apache to 2.4.28+ or 2.2.35+ (requires OS migration per VULN-14). As an immediate mitigation, use ModSecurity or firewall rules to block OPTIONS requests from untrusted sources.

VULN-87 — OpenSSH LoginGraceTime/MaxStartups DoS — Connection Slot Exhaustion

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-400 (Uncontrolled Resource Consumption)
Detected By	Qualys VMDR Basic + Credentialed Scans (OpenSSH 4.7p1; default LoginGraceTime overly long; MaxStartups lacks early release; Qualys Severity 3)
Description	OpenSSH default installations have an excessively long LoginGraceTime and inadequate MaxStartups settings. Remote unauthenticated attackers hold open large numbers of half-authenticated SSH connections, exhausting available slots and preventing legitimate user authentication. SSH is the primary remote management channel for this host.
Impact	Remote unauthenticated attackers exhaust SSH connection slots, denying management access. In an incident response scenario, this DoS could prevent administrators from accessing the host to remediate other vulnerabilities.
Remediation	Reduce LoginGraceTime to 30 seconds in sshd_config. Set MaxStartups 10:30:100. Implement TCP connection rate limiting with iptables. These are all configuration changes achievable without an OS upgrade.

VULN-88 — Samba SWAT XSS and CSRF (CVE-2011-2522/CVE-2011-2694)

Severity	Medium
CVSS Rating	6.1 (CVSS v3.0)
CVE / CWE	CVE-2011-2522 / CVE-2011-2694 / CWE-352 (CSRF) / CWE-79 (XSS)
Detected By	Qualys VMDR Basic Scan (CVE-2011-2522/2694; Samba 3.0.x through 3.5.9 affected; 3.0.20 confirmed)
Description	Two vulnerabilities in the Samba Web Administration Tool (SWAT): CVE-2011-2522 allows CSRF attacks where authenticated SWAT administrators are tricked into performing arbitrary administrative actions. CVE-2011-2694 is reflected XSS via the user field of the Change Password page.
Impact	Attackers who lure SWAT-authenticated Samba administrators into visiting malicious pages can change Samba configuration, add or modify accounts, and change share permissions via CSRF. XSS enables session token theft.
Remediation	Disable SWAT if not operationally required. If required, restrict to localhost only via SSH tunnelling. Apply Samba 3.5.10 patch or upgrade per VULN-14.

VULN-89 — Samba Symlink Directory Traversal — Zero Day (CVE-2010-0926)

Severity	Medium

CVSS Rating	5.8 (CVSS v2.0)
CVE / CWE	CVE-2010-0926 / CWE-22 (Path Traversal)
Detected By	Qualys VMDR Basic Scan (CVE-2010-0926; Metasploit module: auxiliary/admin/smb/samba_symlink_traversal; classified as Zero Day)
Description	Samba allows authenticated SMB users to create symlinks to directories outside the configured share root when wide links are not disabled. An authenticated user can access the symlinked directory via SMB, effectively reading and writing to any filesystem path the Samba daemon can access.
Impact	An authenticated SMB attacker (authentication trivially bypassed given FTP default credentials in VULN-22) can read and write files anywhere on the filesystem accessible to the Samba service, including /etc/shadow, SSL private keys, and all configuration files.
Remediation	Add wide links = no to smb.conf. Enable unix extensions = no. These are immediate configuration changes not requiring an OS upgrade. Upgrade Samba as part of the OS migration (VULN-14).

VULN-90 — ProFTPD Directory Traversal and Buffer Overflow (CVE-2010-3867)

Severity	Medium
CVSS Rating	5.8 (CVSS v2.0)
CVE / CWE	CVE-2010-3867 / CWE-22 (Path Traversal)
Detected By	Qualys VMDR Basic Scan (CVE-2010-3867; ProFTPD 1.3.1 confirmed affected)
Description	ProFTPD 1.3.1 is vulnerable to directory traversal and related buffer overflow in its path handling. Authenticated FTP users can traverse outside their allowed directory. Given that default FTP credentials are confirmed in VULN-22 (multiple accounts accepted), this effectively becomes an unauthenticated file disclosure vulnerability.
Impact	Attackers authenticating via default FTP credentials (confirmed in VULN-22) can read arbitrary files outside the FTP root, including /etc/passwd and configuration files. Combined with VULN-57, VULN-73, and VULN-74, the ProFTPD service has four independently exploitable attack paths.
Remediation	Replace ProFTPD 1.3.1 with version 1.3.8+ as part of the OS migration (VULN-14). This consolidated remediation covers all ProFTPD vulnerabilities simultaneously.

VULN-91 — PHP Session Fixation (CVE-2011-4718)

Severity	Medium
CVSS Rating	5.8 (CVSS v2.0)
CVE / CWE	CVE-2011-4718 / CWE-384 (Session Fixation)
Detected By	Qualys VMDR Basic Scan (CVE-2011-4718 Sev 4; PHP 5.2.4 confirmed on port 80/tcp; PHP >= 5.5.2 required for fix)
Description	PHP versions prior to 5.5.2 allow session fixation attacks. An attacker can set a known session ID in a victim's browser before authentication. After the victim authenticates, the attacker uses that pre-set session ID to hijack the authenticated session.
Impact	Attackers can set a known session ID before victims authenticate to any PHP application on this host (DVWA, Mutillidae, phpMyAdmin, TWiki, TikiWiki). After authentication, the attacker immediately accesses the application as the victim without knowing the password.
Remediation	Upgrade PHP to 5.5.2+ (requires OS migration per VULN-14). As an interim measure, add session_regenerate_id(true) in application code on successful login.

VULN-92 — APR-util Library Integer Overflow — Remote Code Execution Vector

Severity	Medium
CVSS Rating	5.1 (CVSS v2.0)
CVE / CWE	CWE-190 (Integer Overflow) / CWE-122 (Heap-Based Buffer Overflow)
Detected By	Qualys VMDR Basic Scan (APR-util Integer Overflow; Apache 2.2.8 uses affected APR-util version)
Description	The APR-util library bundled with Apache HTTP Server 2.2.8 contains integer overflow vulnerabilities in memory allocation functions. When processing malicious input through Apache modules using APR-util (mod_proxy, mod_dav, and others), the integer overflow can lead to heap buffer overflows.
Impact	Remote attackers sending crafted requests through Apache modules using APR-util memory allocation can trigger integer overflows leading to heap corruption and potentially arbitrary code execution as the Apache worker process.
Remediation	Upgrade Apache HTTP Server to 2.4.x which bundles a fixed APR-util version (requires OS migration per VULN-14).

VULN-93 — OpenSSH Username Enumeration via Timing Side-Channel (CVE-2016-6210)

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CVE-2016-6210 / CWE-208 (Observable Timing Discrepancy)
Detected By	Qualys VMDR Basic Scan (CVE-2016-6210; OpenSSH 4.7p1 < fixed 7.3; timing oracle allows username enumeration)
Description	OpenSSH prior to 7.3 uses different processing times when checking passwords for valid versus invalid usernames. This timing discrepancy allows remote enumeration of valid usernames. Given the Weak Debian SSH keys (VULN-13) have potentially compromised private keys for all system accounts, valid username enumeration directly assists targeting those compromised keys.
Impact	Remote unauthenticated attackers enumerate all valid system usernames via SSH response timing. This directly assists in targeting compromised Debian SSH keys (VULN-13), .rhosts authentication (VULN-48), and brute-force attacks against rlogin/rsh/rexec services (VULN-16).
Remediation	Upgrade OpenSSH to 7.3+ (requires OS migration per VULN-14). No mitigation available on OpenSSH 4.7p1 without upgrade.

VULN-94 — OpenSSH X11 Hijacking Attack (CVE-2008-1483)

Severity	Medium
CVSS Rating	6.9 (CVSS v2.0)
CVE / CWE	CVE-2008-1483 / CWE-264 (Permissions, Privileges, and Access Controls)
Detected By	Qualys VMDR Basic Scan (CVE-2008-1483; OpenSSH 4.7p1 < fixed 5.0; X Server detected per VULN-40)
Description	OpenSSH prior to 5.0 binds X11 forwarding sockets to all local addresses rather than only loopback, allowing local users to hijack X11 sessions of other users. Combined with the confirmed X Server detection (VULN-40), this vulnerability is fully exploitable on this host.
Impact	Local users or remote attackers who have achieved shell access via any RCE vulnerability can intercept X11 sessions of other users, capturing keyboard input, screen contents, and potentially injecting X11 events for privilege escalation.
Remediation	Upgrade OpenSSH to 5.0+ (requires OS migration per VULN-14). Immediately disable X11 forwarding in sshd_config: X11Forwarding no. This eliminates the attack vector entirely and also addresses VULN-95.

VULN-95 — OpenSSH CRLF Injection via X11 Forwarding (CVE-2016-3115)

Severity	Medium
CVSS Rating	5.5 (CVSS v3.0)
CVE / CWE	CVE-2016-3115 / CWE-93 (Improper Neutralisation of CRLF Sequences)
Detected By	Qualys VMDR Basic Scan (CVE-2016-3115; OpenSSH 4.7p1 < fixed 7.2p2)
Description	OpenSSH prior to 7.2p2 does not sanitise newline characters in X11 forwarding request parameters. Authenticated users with X11 forwarding access can inject CRLF sequences into xauth command arguments, enabling injection of arbitrary xauth commands.
Impact	Authenticated SSH users can inject arbitrary xauth commands via crafted X11 forwarding parameters, potentially enabling session hijacking, adding unauthorised X authentication credentials, or executing arbitrary commands within the X11 authentication context.
Remediation	Upgrade OpenSSH to 7.2p2+ (requires OS migration per VULN-14). Disable X11 forwarding as an immediate mitigation (X11Forwarding no in sshd_config), which also addresses VULN-94.

VULN-96 — Apache mod_setenvif Integer Overflow — Heap Buffer Overflow (CVE-2011-3607)

Severity	Medium
CVSS Rating	4.4 (CVSS v2.0)
CVE / CWE	CVE-2011-3607 / CWE-190 (Integer Overflow)
Detected By	Qualys VMDR Basic Scan (CVE-2011-3607; Apache 2.2.8 < fixed 2.2.21; SetEnvIf directive processing)
Description	Apache HTTP Server prior to 2.2.21 contains an integer overflow in mod_setenvif when processing SetEnvIf directives with crafted HTTP request headers. The overflow triggers a heap buffer overflow.
Impact	Remote attackers send specially crafted HTTP request headers triggering the mod_setenvif integer overflow, potentially leading to heap corruption and process crashes (DoS) or code execution as the Apache worker process.
Remediation	Upgrade Apache to 2.2.21+ (requires OS migration per VULN-14). As an interim measure, remove or restrict SetEnvIf directives in httpd.conf if not operationally required.

VULN-97 — jQuery 1.3.2 Additional CVEs — Prototype Pollution and XSS (CVE-2019-11358 et al.)

Severity	Medium
CVSS Rating	6.1 (CVSS v3.0)
CVE / CWE	CVE-2019-11358 / CVE-2020-11022 / CVE-2020-11023 / CVE-2020-7656 / CWE-1321 (Prototype Pollution)
Detected By	ZAP Active Scan (CVE-2019-11358, CVE-2020-11022, CVE-2020-11023, CVE-2020-7656 confirmed; jQuery 1.3.2 at /mutillidae/javascript/ddsmoothmenu/jquery.min.js)
Description	jQuery 1.3.2 is affected by four additional CVEs beyond those in VULN-53. CVE-2019-11358 is prototype pollution via $.extend(true, ...) affecting jQuery below 3.4.0. CVE-2020-11022 and CVE-2020-11023 are XSS via the html() method affecting jQuery below 3.5.0. CVE-2020-7656 is XSS via the load() method affecting jQuery below 1.9.0. VULN-53 documents only two of six confirmed jQuery CVEs affecting the installed version.
Impact	Prototype pollution can corrupt JavaScript object properties application-wide and enable denial of service. The additional XSS CVEs provide further client-side attack

	paths beyond VULN-53. VULN-53 must be understood as documenting only two of six confirmed jQuery CVEs.
Remediation	Upgrade jQuery to 3.7.1+ as documented in VULN-53. All six CVEs affecting jQuery 1.3.2 are resolved by this single upgrade. No intermediate version should be targeted as multiple vulnerabilities affect versions up to 3.4.x.

VULN-98 — SSL Certificate RSA Public Key Strength Below 2048 Bits

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-326 (Inadequate Encryption Strength)
Detected By	Greenbone OpenVAS (SSL/TLS Server Certificate with RSA key less than 2048 bits NVT; multiple SSL-enabled services confirmed)
Description	SSL/TLS certificates on this host use RSA public keys below the minimum recommended 2048 bits. Keys below 2048 bits are computationally feasible to factor using modern hardware and are deprecated by NIST, CA/Browser Forum, and all major browsers. This is in addition to the SSL/TLS weaknesses in VULN-12 and VULN-28.
Impact	Weak RSA keys make the SSL/TLS private key susceptible to offline factoring. If recovered, the attacker can decrypt all past TLS sessions (no Perfect Forward Secrecy on this host) and impersonate the server.
Remediation	Replace all SSL/TLS certificates with ones using at minimum 2048-bit RSA keys (preferably 4096-bit or ECDSA P-256). This is a standalone certificate replacement that does not require an OS upgrade and should be actioned as part of VULN-12 and VULN-28 remediation.

VULN-99 — Unix Timestamp Disclosure — Systemic Across TWiki Application Pages

Severity	Low
CVSS Rating	3.1 (CVSS v3.0)
CVE / CWE	CWE-200 (Information Exposure)
Detected By	ZAP Active Scan (Timestamp Disclosure - Unix; systemic across /twiki/bin/view/Main/OfficeLocations, TWikiGroups, TWikiUsers; epoch value 1771897092 confirmed)
Description	ZAP confirmed systemic Unix timestamp disclosure across multiple TWiki pages. The epoch value 1771897092 (resolving to 2026-02-23 20:38:12 UTC) was returned in response content. Confirms TWiki is actively serving pages and that server time is known to attackers.
Impact	Precise server time combined with the Weak Debian SSH keys (VULN-13) assists in predicting sequence numbers and authentication tokens generated using the compromised entropy source. Low impact in isolation but contextually relevant given other cryptographic weaknesses.
Remediation	Suppress server-generated timestamps from HTTP response content. Upgrade TWiki to remove unintended information disclosure from page templates. Low priority relative to other findings on this host.

VULN-100 — SSH Server Weak Host Key Algorithm Supported

Severity	Low
CVSS Rating	3.7 (CVSS v3.0)
CVE / CWE	CWE-326 (Inadequate Encryption Strength)

Detected By	Greenbone OpenVAS (Weak Host Key Algorithm NVT; SSH service on port 22/tcp; weak host key algorithms advertised)
Description	The SSH server on port 22/tcp advertises host key algorithms with insufficient cryptographic strength. This adds to the weak key exchange and MAC algorithm weaknesses in VULN-33. Together, CBC ciphers, weak MACs, weak KEX, and weak host key algorithms represent a comprehensively insecure SSH configuration.
Impact	Weak host key algorithms reduce SSH server authentication strength, potentially enabling server impersonation attacks when combined with traffic interception capability. The risk is incremental over KEX and cipher weaknesses in VULN-33.
Remediation	Add to sshd_config remediation in VULN-33: HostKeyAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,ssh-ed25519. Remove RSA-SHA1 and DSA host key algorithms. This configuration change is achievable without an OS upgrade.

VULN-101 — Harvest Now / Decrypt Later — Post-Quantum Cipher Exposure Risk	
Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-327 (Use of Broken or Risky Cryptographic Algorithm) - Forward-Looking
Detected By	Nessus Basic + Credentialed Scans (Plugins 277650 - Remote Services Not Using Post-Quantum Ciphers; 298387 - Shor's Harvest Now Decrypt Later)
Description	Nessus flagged all SSL/TLS and SSH services as not using post-quantum cipher suites. The Harvest Now / Decrypt Later (HNDL) threat describes adversaries who capture encrypted traffic today for future decryption once quantum computers become available. RSA and ECDH key exchange algorithms used exclusively on this host are vulnerable to Shor's algorithm on a cryptographically relevant quantum computer.
Impact	Any encrypted traffic captured from this host today may be decryptable in the future. For a system already comprehensively compromised at plaintext level via active backdoors, this is an informational finding. In production contexts handling long-term sensitive data, HNDL is a strategic planning concern.
Remediation	Incorporate post-quantum cryptography migration into long-term infrastructure planning using NIST PQC standards (FIPS 203/204/205). For SSH, OpenSSH 9.0+ supports hybrid PQC KEX. Not actionable for the current EOL system but should inform the replacement architecture.

7.5 Remediation Roadmap: Metasploitable 2

Priority	Timeframe	Action	Severity
P1	<24 hrs	ISOLATE the host from all networks. Block all traffic to 10.0.2.4. Treat as actively compromised.	**Critical**
P2	<24 hrs	Remove all four active backdoors immediately. (1) Kill Ingreslock process on port 1524 (VULN-01). (2) Remove vsftpd 2.3.4 and block port 6200 (VULN-02). (3) Remove UnrealIRCd and block ports 6667/6697 (VULN-03). (4) Remove ProFTPD 1.3.3c, replace with 1.3.8+, and block ports 2121/tcp and 6200/tcp (VULN-57). All ProFTPD vulnerabilities (VULN-57, VULN-73, VULN-74, VULN-90) are resolved by this single replacement. Also terminate MySQL default root (port 3306) and PostgreSQL default credentials (port 5432). Kill all backdoor processes and remove persistence mechanisms.	**Critical**

P3	<72 hrs	Plan and execute OS migration: rebuild on Ubuntu 22.04/24.04 LTS from a trusted base image. This single action resolves: all EOL software (VULN-14, VULN-15, VULN-77 Apache HTTP EOL), the Samba RCE family (VULN-59, VULN-61, VULN-69, VULN-70, VULN-71, VULN-72), all OpenSSH vulnerabilities (VULN-93, VULN-94, VULN-95), APR-util overflow (VULN-92), PHP session fixation (VULN-91), Vim buffer overflow (VULN-84), and the majority of all other CVEs on this host.	**Critical**
P4	<1 week	Patch Bash (Shellshock, VULN-04), PHP CGI (CVE-2012-1823 VULN-07, plus bypass variants CVE-2012-2335/2336 VULN-75, and source disclosure VULN-66: disable PHP CGI mode entirely, set cgi.force_redirect=1), Tomcat Ghostcat (VULN-05), disable DistCC (VULN-11). Apply all security updates on the new OS.	**Critical**
P5	<1 week	(1) Change or remove Tomcat Manager credentials on port 8080 (VULN-43) AND port 8180 (VULN-58: separate Tomcat instance with default tomcat:tomcat confirmed; apply RemoteAddrValve and shut down port 8180 if unused). (2) Disable anonymous FTP login (VULN-50). (3) Disable TFTP service or restrict to read-only chroot jail (VULN-44). (4) Delete or restrict /tikiwiki/tiki-install.php (VULN-60). (5) Delete or restrict /phpinfo.php; set expose_php=Off (VULN-63).	**Critical**
P6	<1 week	(1) Disable Telnet (VULN-27), rlogin, rsh, rexec (VULN-16). (2) Change VNC password (VULN-06). Remove FTP weak accounts (VULN-22). (3) Set X11Forwarding no in sshd_config: resolves X11 hijacking (VULN-94) and CRLF injection (VULN-95) simultaneously. (4) Verify UnrealIRCd is upgraded to 3.2.10.7+ to patch auth spoofing CVE-2016-7144 (VULN-62) in addition to the backdoor (VULN-03). (5) Add to httpd.conf immediately: RangeOverlaps 0 and RequestRange 3 200 to mitigate Apache Killer DoS (VULN-76). Block all legacy service ports at the network perimeter.	**High**
P7	<1 week	Revoke all SSL/SSH keys generated on this host (Debian weak RNG). Regenerate on patched system and update trust stores.	**High**
P8	<1 week	Remove all .rhosts files and the /etc/hosts.equiv wildcard entry. Disable SMTP VRFY command (disable_vrfy_command=yes in Postfix) (VULN-48, VULN-49).	**High**
P9	<2 weeks	Replace all dynamic SQL with parameterised queries. Suppress database error messages. Disable WebDAV PUT/DELETE. Remediate RFI and SSI injection.	**High**
P10	<2 weeks	(1) Implement output encoding on all user-supplied data. (2) Upgrade TWiki to 4.3.2+ (resolves CVE-2008-5304/5305 VULN-18, CVE-2005-2877 VULN-65, CSRF CVE-2009-4898 VULN-80 simultaneously). (3) Set HttpOnly/Secure cookie flags. (4) Verify TWiki upgrade includes the token-based CSRF fix (SecurityAuditTokenBasedCsrfFix).	**High**
P11	<1 month	(1) Remove Apache Log4j 1.x; migrate to Log4j 2.17.1+ (VULN-47). (2) Upgrade phpMyAdmin to current stable release 5.x: resolves XSS (VULN-46), setup.php RCE CVE-2009-1151 (VULN-64), and error.php XSS CVE-2010-4480 (VULN-82) simultaneously. Delete /scripts/setup.php if upgrade is delayed. (3) Enforce mandatory SMB signing in smb.conf (VULN-45).	**High**
P12	<1 month	(1) Disable SSLv2/v3, RC4, EXPORT ciphers, weak DH parameters. Enforce TLS 1.2+ across all services. Patch OpenSSL CCS Injection (VULN-26). (2) Replace all SSL/TLS certificates with RSA keys of 2048 bits minimum (VULN-98). (3) Add SSL_OP_NO_RENEGOTIATION to SSL context configuration to prevent renegotiation DoS CVE-2011-1473 (VULN-79). (4) Deploy TLS/HTTPS across all web applications; enforce HTTPS-only with HSTS headers to prevent cleartext credential interception (VULN-83): affects DVWA, phpMyAdmin, TikiWiki, and TWiki login forms.	**Medium**

P13	<1 month	(1) Restrict NFS exports to trusted IPs; restrict RPC/mountd access at firewall (mitigates NFS-Utils Xlog CVE-2003-0252 VULN-68 until OS migration). (2) Add to smb.conf immediately: wide links=no and unix extensions=no (mitigates Samba symlink traversal CVE-2010-0926 VULN-89). (3) Disable SWAT or restrict to localhost only (VULN-88: CVE-2011-2522/2694). (4) Upgrade Samba to 4.13.17+ via OS migration to resolve all six Samba RCE CVEs: CVE-2007-2447 (VULN-21), CVE-2007-2446 (VULN-61), CVE-2008-1105 (VULN-69), CVE-2010-2063 (VULN-70), CVE-2012-1182 (VULN-71), CVE-2007-6015 (VULN-72), CVE-2021-44142 (VULN-59), CVE-2022-45141 (VULN-67). (5) Upgrade PostgreSQL to v10+; configure SCRAM-SHA-256 in pg_hba.conf (resolves PassTheHash weakness VULN-85). (6) Upgrade BIND. Enable SMB signing.	**Medium**
P14	<2 months	(1) Add security headers: CSP, X-Frame-Options, X-Content-Type-Options (VULN-31). (2) Disable HTTP TRACE (VULN-30). Suppress server version tokens. Suppress all error output. (3) Block HTTP OPTIONS requests via ModSecurity or firewall rule to mitigate Apache OptionsBleed CVE-2017-9798 (VULN-86) until OS migration. (4) Remove or restrict SetEnvIf directives in httpd.conf to reduce mod_setenvif integer overflow CVE-2011-3607 attack surface (VULN-96).	**Medium**
P15	<2 months	(1) Upgrade jQuery to 3.7.1+: resolves CVE-2012-6708/CVE-2011-4969 (VULN-53) plus CVE-2019-11358, CVE-2020-11022/23, CVE-2020-7656 (VULN-97) simultaneously. (2) Disable SSL anonymous cipher suites across all TLS services (VULN-52). (3) Set HttpOnly and SameSite cookie flags in php.ini (VULN-55). (4) Disable directory listing (VULN-54). (5) Suppress internal IP disclosure from HTTP responses (VULN-56).	**Medium**
P16	<2 months	(1) Address path traversal (VULN-23), open redirects (VULN-34), SSH weak algorithms (VULN-33); add HostKeyAlgorithms directive to sshd_config to also fix weak host key algorithm (VULN-100). (2) Restrict dRuby (VULN-08). Disable X server remote access (VULN-40). Remove IRC (VULN-41). Implement CSRF tokens (VULN-42). (3) Disable Java RMI Registry service or restrict port at firewall (VULN-78). (4) Set LoginGraceTime 30 and MaxStartups 10:30:100 in sshd_config (VULN-87). (5) Restrict intentionally vulnerable apps (DVWA, Mutillidae, TWiki, phpMyAdmin) to isolated training network; do not expose on any production or internet-facing interface (VULN-81). (6) Incorporate post-quantum cryptography migration into long-term architecture planning using NIST PQC standards FIPS 203/204/205 (VULN-101). (7) Suppress Unix timestamp disclosure from TWiki page output (VULN-99). (8) Add session_regenerate_id(true) on login for PHP session fixation mitigation (VULN-91) pending OS migration.	**Low**

8. Target 2: VulnWeb Application (testphp.vulnweb.com)

8.1 Target Profile

Target Host:	testphp.vulnweb.com (44.228.249.3)
Port:	80 (HTTP only, no HTTPS)
Technology Stack:	PHP 5.6.40 / nginx 1.19.0 / MySQL
Application Type:	PHP e-commerce web application
Key Endpoints:	artists.php, listproducts.php, product.php, search.php, guestbook.php, cart.php, newuser.php, userinfo.php, showimage.php
Tools Used:	OWASP ZAP v2.17.0, Tenable Nessus (×2), Greenbone OpenVAS, Nikto v2.5.0
Assessment Period:	20 – 26 February 2026
Overall Rating:	CRITICAL - IMMEDIATELY VULNERABLE

The application runs an end-of-life PHP version with no security patches since December 2018. SQL injection is confirmed across six core endpoints, XSS across all major pages, and the entire application is served over unencrypted HTTP. Immediate remediation is required.

8.2 Risk Summary

Severity	Count	Description
Critical	2	Immediate exploitation likely. Full system or data compromise.
High	3	Confirmed exploitable with significant direct impact.
Medium	4	Exploitable under realistic conditions or via attack chains.
Low	4	Minor direct impact; provides useful information to attackers.
Informational	5	Attack surface items requiring manual review.
TOTAL FINDINGS	**18**	2 Critical | 3 High | 4 Medium | 4 Low | 5 Informational

8.3 Vulnerability Index

All 18 findings listed in priority order:

ID	Vulnerability	Severity	CVSS	Detected By
VULN-01	Unsupported PHP Version (PHP 5.6.40)	**Critical**	10.0	Nessus VulnWeb Test Scan (Plugin 58987)
VULN-02	SQL Injection — MySQL (Error-Based & Time-Based Blind)	**Critical**	9.8	ZAP (9 error-based + 5 time-based instances across artists.php, listproducts.php, product.php, search.php, newuser.php, userinfo.php)
VULN-03	Cross-Site Scripting (XSS) — Reflected & Stored	**High**	8.8	ZAP (19 confirmed instances across artists.php, hpp/, hpp/params.php, listproducts.php, product.php, guestbook.php,

				search.php, newuser.php, userinfo.php)
VULN-04	XSLT Injection	**High**	8.1	ZAP (2 instances — showimage.php, file and file+size parameters)
VULN-05	Cleartext Transmission of Sensitive Data — No HTTPS	**High**	7.5	ZAP (HTTP Only Site)
VULN-06	phpinfo() Page Publicly Accessible	**Medium**	5.3	Greenbone/OpenVAS (Medium, QoD 80%)
VULN-07	Cross-Site Request Forgery (CSRF) — Missing Anti-CSRF Tokens	**Medium**	6.5	ZAP (Systemic — confirmed across root, cart.php, categories.php, disclaimer.php, index.php)
VULN-08	Missing Content Security Policy (CSP) Header	**Medium**	5.4	ZAP (Systemic — Medium)
VULN-09	Clickjacking — Missing X-Frame-Options / CSP frame-ancestors	**Medium**	5.4	ZAP (Systemic — Medium)
VULN-10	Server & Technology Version Information Disclosure	**Low**	5.3	ZAP (Systemic — X-Powered-By, Server header, In-Page Banner at /high, /robots.txt, /sitemap.xml)
VULN-11	Missing X-Content-Type-Options Header	**Low**	4.3	ZAP (Systemic — Low)
VULN-12	Overly Permissive Cross-Domain Policy Files	**Low**	4.0	Nikto (/crossdomain.xml wildcard, /clientaccesspolicy.xml wildcard + 12 lines)
VULN-13	Browser Password Autocomplete Not Disabled	**Low**	2.6	Nessus WebAPP Scan (Low — Plugin 42057)
VULN-14	CGI Parameter Injection Surface — Unvalidated Input Parameters	**Informational**	N/A	Nessus WebAPP Scan (Plugins 47830 — CGI Generic Injectable Parameter, 40773 — Potentially Sensitive CGI Parameter Detection)
VULN-15	POST Endpoints Accept GET Requests — Unsafe HTTP Method Handling	**Informational**	N/A	ZAP (3 instances — cart.php?addcart=7&price=15000, guestbook.php, search.php)
VULN-16	HTTP / HTML Charset Mismatch (Potential UTF-7 XSS Vector)	**Informational**	N/A	ZAP (Systemic — root, AJAX/index.php, cart.php, categories.php, index.php)
VULN-17	Information Disclosure — Directory Enumeration & Exposed Email Addresses	**Informational**	N/A	Nessus WebAPP Scan (Plugin 11032 — Web Server Directory Enumeration, Plugin 49705 — Harvested Email Addresses)
VULN-18	Unrestricted HTTP Methods Enabled Per Directory	**Informational**	N/A	Nessus WebAPP Scan (Plugin 43111 — HTTP Methods Allowed per directory)

8.4 Detailed Findings

Full technical detail for each of the 18 identified vulnerabilities:

VULN-01 — Unsupported PHP Version (PHP 5.6.40)	
Severity	Critical

CVSS Rating	10.0 (CVSS v3.0)
CVE / CWE	CWE-1104 — PHP 5.6 EOL: 31 December 2018
Detected By	Nessus VulnWeb Test Scan (Plugin 58987); Nikto
Description	The server is running PHP 5.6.40, which reached end-of-life on 31 December 2018. No security patches or updates are provided for this version. The exact version string is further exposed via the X-Powered-By response header (PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1) on every page, giving attackers a precise target.
Impact	Full server compromise via exploitation of any of the numerous publicly documented, unpatched PHP 5.6 vulnerabilities. Risk of remote code execution, privilege escalation, and complete data exfiltration.
Remediation	Upgrade immediately to the latest stable PHP 8.3.x release. Test application compatibility against the PHP 8.3 migration guide. Update all deprecated functions. Suppress the version header by setting expose_php = Off in php.ini.

VULN-02 — SQL Injection — MySQL (Error-Based & Time-Based Blind)

Severity	Critical
CVSS Rating	9.8 (CVSS v3.0)
CVE / CWE	CWE-89 / WASC-19
Detected By	ZAP (9 error-based + 5 time-based instances across artists.php, listproducts.php, product.php, search.php, newuser.php, userinfo.php)
Description	SQL injection was confirmed across six core endpoints. Error-based injection returns raw MySQL syntax errors directly to the user. Time-based blind injection (SLEEP(15)) was confirmed by 15-second response delays on five endpoints. User input is concatenated directly into SQL queries without sanitisation or parameterisation, and raw database error messages are returned to the browser.
Impact	Complete database compromise — extraction, modification, or deletion of all records including user credentials, credit card data, and personal information. Potential OS-level command execution depending on MySQL user privileges.
Remediation	Replace all dynamic SQL with PDO prepared statements or MySQLi parameterised queries throughout the entire codebase. Apply server-side type validation. Restrict MySQL account privileges to the minimum required. Suppress all database error messages from end users — log internally only.

VULN-03 — Cross-Site Scripting (XSS) — Reflected & Stored

Severity	High
CVSS Rating	8.8 (CVSS v3.0)
CVE / CWE	CWE-79 / WASC-8
Detected By	ZAP (19 confirmed instances across artists.php, hpp/, hpp/params.php, listproducts.php, product.php, guestbook.php, search.php, newuser.php, userinfo.php)
Description	Reflected XSS was confirmed via script and event-handler injection across all major pages. Notably, guestbook.php is vulnerable via POST fields (name, text), indicating likely stored/persistent XSS — any visitor to the guestbook is attacked without interaction. Two additional user-controllable HTML attribute hotspots were identified on guestbook.php and search.php. User input is rendered in responses without encoding.
Impact	Session hijacking, cookie theft, account takeover, credential harvesting, malware distribution, and defacement. Stored XSS on guestbook.php automatically attacks all visitors. Combined with absent CSRF tokens, XSS bypasses all CSRF protections.
Remediation	Apply context-aware HTML output encoding on all user-supplied data (htmlspecialchars() with ENT_QUOTES minimum in PHP). Set HttpOnly and Secure

	flags on all session cookies. Implement a Content Security Policy. Treat guestbook.php as highest priority due to stored XSS.

VULN-04 — XSLT Injection

Severity	High
CVSS Rating	8.1 (CVSS v3.0)
CVE / CWE	CWE-91 / WASC-23
Detected By	ZAP (2 instances — showimage.php, file and file+size parameters)
Description	The 'file' parameter in showimage.php accepts unsanitised XSL transformation directives. ZAP injected an XSL document() function call and received confirmation of server-side processing, with the server attempting outbound network connections. This demonstrates both SSRF capability and internal port scanning.
Impact	Arbitrary local file read (including configuration files and credentials), internal network port scanning via SSRF, and potential remote code execution via XSLT extension functions.
Remediation	Apply a strict allowlist to the 'file' parameter (alphanumeric and limited safe characters only). Disable external document/entity resolution in the XSLT processor (libxml_disable_entity_loader(true) in PHP). Remove the XSLT processing functionality if not required.

VULN-05 — Cleartext Transmission of Sensitive Data — No HTTPS

Severity	High
CVSS Rating	7.5 (CVSS v3.0)
CVE / CWE	CWE-311 / CWE-319 / WASC-4
Detected By	ZAP (HTTP Only Site); Greenbone/OpenVAS (CVSS 4.8 — login.php:pass, signup.php:upass confirmed); Nessus WebAPP Scan (Web Server Transmits Cleartext Credentials)
Description	The entire application is served over unencrypted HTTP with no HTTPS endpoint. All session tokens, login credentials, registration data, and credit card numbers are transmitted in cleartext. Greenbone confirmed password field transmission on login.php and signup.php. Three independent tools flagged this issue.
Impact	Any attacker with network access can passively intercept all credentials, session tokens, and payment data using standard tools. Constitutes a likely PCI-DSS and GDPR compliance violation.
Remediation	Deploy a TLS 1.2+ certificate (free via Let's Encrypt/Certbot). Configure nginx for HTTPS only on port 443 with an HTTP 301 redirect from port 80. Implement HSTS (Strict-Transport-Security: max-age=31536000; includeSubDomains). Apply the Secure attribute to all cookies.

VULN-06 — phpinfo() Page Publicly Accessible

Severity	Medium
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CVE-2008-0149, CVE-2023-49282, CVE-2023-49283, CVE-2024-10486
Detected By	Greenbone/OpenVAS (Medium, QoD 80%)
Description	The file /secured/phpinfo.php is publicly accessible without authentication and outputs the full phpinfo() result, including: PHP version, php.ini file path (/usr/local/etc/php.ini), all loaded modules and their configurations, server environment variables, and web root directory. The file resides under /secured/, indicating authentication was intended but not enforced.

Impact	Attackers obtain a complete server fingerprint enabling precision-targeted exploitation. May also expose database connection strings or API keys set as environment variables.
Remediation	Delete /secured/phpinfo.php immediately. Audit for other diagnostic files (info.php, test.php). Enforce authentication on all paths under /secured/. Add a server-level nginx deny rule: location ~* phpinfo { deny all; }

VULN-07 — Cross-Site Request Forgery (CSRF) — Missing Anti-CSRF Tokens

Severity	Medium
CVSS Rating	6.5 (CVSS v3.0)
CVE / CWE	CWE-352 / WASC-9
Detected By	ZAP (Systemic — confirmed across root, cart.php, categories.php, disclaimer.php, index.php)
Description	No CSRF tokens are present on any form across the application. All forms — including search, guestbook, cart, registration, and login — lack per-session nonce protection. This is systemic across all tested pages. Risk is significantly elevated by confirmed XSS vulnerabilities, which bypass CSRF defences entirely. Additionally, cart.php accepts GET requests (see VULN-15), meaning cart manipulation requires no form submission at all.
Impact	Attackers can forge authenticated requests on behalf of logged-in users: adding items to cart, posting guestbook entries, submitting registrations, or changing account details — all without user knowledge.
Remediation	Generate a cryptographically random per-session CSRF token, embed it as a hidden field in all forms, and validate server-side on every state-changing request. Use OWASP CSRFGuard or equivalent. Enforce POST-only on all state-changing endpoints.

VULN-08 — Missing Content Security Policy (CSP) Header

Severity	Medium
CVSS Rating	5.4 (CVSS v3.0)
CVE / CWE	CWE-693 / WASC-15
Detected By	ZAP (Systemic — Medium); Nessus WebAPP Scan (Plugin 50344 — Missing CSP frame-ancestors)
Description	No Content-Security-Policy header is set on any page. CSP is the primary browser-enforced control that would restrict script execution and significantly limit the impact of the confirmed XSS vulnerabilities. Its absence means all injected scripts execute without restriction and can load resources from any external domain.
Impact	All confirmed XSS attacks operate without any browser-level restriction, enabling data exfiltration to attacker-controlled servers and arbitrary script execution in victim sessions.
Remediation	Configure nginx to return a CSP header. Begin with report-only mode to identify issues, then enforce: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none';

VULN-09 — Clickjacking — Missing X-Frame-Options / CSP frame-ancestors

Severity	Medium
CVSS Rating	5.4 (CVSS v3.0)
CVE / CWE	CWE-1021 / WASC-15

Detected By	ZAP (Systemic — Medium); Nessus WebAPP Scan (Medium CVSS 4.3, Plugin 85582); Nessus (Plugin 50345 — Missing X-Frame-Options); Nikto
Description	Both the X-Frame-Options header and the CSP frame-ancestors directive are absent from all responses. Confirmed independently by four sources. The application can be embedded in a transparent iframe on any third-party website, enabling clickjacking attacks.
Impact	Users can be deceived into performing unintended actions (submitting orders, changing account settings) via a transparent overlay. Compounded by missing CSRF tokens.
Remediation	Add X-Frame-Options: DENY to all nginx responses: add_header X-Frame-Options 'DENY' always; This is also addressed by the CSP frame-ancestors 'none' directive in VULN-08 remediation.

VULN-10 — Server & Technology Version Information Disclosure

Severity	Low
CVSS Rating	5.3 (CVSS v3.0)
CVE / CWE	CWE-497 / WASC-13
Detected By	ZAP (Systemic — X-Powered-By, Server header, In-Page Banner at /high, /robots.txt, /sitemap.xml); Nessus (HTTP Server Type and Version, nginx Detection); Nikto
Description	Version information is exposed via three channels: (1) X-Powered-By header discloses PHP/5.6.40-38+ubuntu20.04.1 systemically; (2) Server header discloses nginx/1.19.0 systemically; (3) The nginx version string appears directly in the response body on error and resource pages. nginx 1.19.0 (released 2020) has multiple known CVEs.
Impact	Attackers can cross-reference both PHP 5.6 and nginx 1.19.0 against public exploit databases to obtain a ready-made attack plan with minimal research.
Remediation	Set server_tokens off; in nginx.conf to suppress the Server header and error page versions. Set expose_php = Off in php.ini to remove the X-Powered-By header. Implement custom error pages.

VULN-11 — Missing X-Content-Type-Options Header

Severity	Low
CVSS Rating	4.3 (CVSS v3.0)
CVE / CWE	CWE-693 / WASC-15
Detected By	ZAP (Systemic — Low); Nikto
Description	The X-Content-Type-Options: nosniff header is absent from all responses, confirmed by both ZAP and Nikto. Without this header, browsers may perform MIME-type sniffing and interpret a response as a different content type than declared, potentially executing non-script files as JavaScript.
Impact	MIME-sniffing may allow browsers to execute uploaded or injected content as scripts. Risk is elevated in the presence of confirmed XSS vulnerabilities.
Remediation	Add add_header X-Content-Type-Options 'nosniff' always; to nginx configuration. This is a single-line change with no functional impact on legitimate traffic.

VULN-12 — Overly Permissive Cross-Domain Policy Files

Severity	Low
CVSS Rating	4.0 (CVSS v2.0)
CVE / CWE	CWE-942

Detected By	Nikto (/crossdomain.xml wildcard, /clientaccesspolicy.xml wildcard + 12 lines); Nessus (Plugins 72427, 32318)
Description	Both /crossdomain.xml and /clientaccesspolicy.xml contain full wildcard entries (*), permitting any domain to make cross-domain requests via Flash and Silverlight clients. Confirmed by both Nikto and Nessus.
Impact	Legacy plugin-based clients can bypass the same-origin policy, enabling cross-domain data theft from authenticated user sessions.
Remediation	Remove wildcard entries. If cross-domain access is not required, delete both files. If required, restrict allow-access-from to explicitly named trusted domains only.

VULN-13 — Browser Password Autocomplete Not Disabled

Severity	Low
CVSS Rating	2.6 (CVSS v2.0)
CVE / CWE	OWASP A07:2021 — Plugin 42057
Detected By	Nessus WebAPP Scan (Low — Plugin 42057)
Description	Password and sensitive input fields on authentication forms do not include the autocomplete='off' or autocomplete='new-password' attribute, allowing browsers to cache and autofill credentials on shared or public devices.
Impact	Cached credentials on shared or compromised devices can be accessed by subsequent users or malicious browser extensions.
Remediation	Add autocomplete='new-password' to all password input fields and autocomplete='off' to other sensitive fields (e.g., credit card numbers) in all authentication and registration forms.

VULN-14 — CGI Parameter Injection Surface — Unvalidated Input Parameters

Severity	Informational
CVSS Rating	N/A
CVE / CWE	OWASP A03:2021 — Plugins 47830, 40773
Detected By	Nessus WebAPP Scan (Plugins 47830 — CGI Generic Injectable Parameter, 40773 — Potentially Sensitive CGI Parameter Detection)
Description	Nessus identified CGI parameters potentially susceptible to injection and parameters flagged as potentially sensitive. These findings corroborate the confirmed SQL injection and XSS findings from ZAP and indicate additional attack surface that may not have been fully exercised by automated scanning.
Impact	May indicate injection points or sensitive parameters beyond those already confirmed. Requires manual review to determine full scope.
Remediation	Perform manual penetration testing on all CGI parameters identified by Nessus. Apply the same parameterised query and input validation controls recommended under VULN-02 and VULN-03 to all identified parameters.

VULN-15 — POST Endpoints Accept GET Requests — Unsafe HTTP Method Handling

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-16 / WASC-20
Detected By	ZAP (3 instances — cart.php?addcart=7&price=15000, guestbook.php, search.php)
Description	Three POST-only endpoints accept GET requests: cart.php (items can be added to a user's cart via a crafted URL: ?addcart=7&price=15000), guestbook.php (entries can

	be submitted via URL), and search.php. The cart.php issue is particularly significant — an attacker can manipulate a victim's cart by embedding a link, with no form submission or CSRF token required.
Impact	cart.php: an attacker can add arbitrary items at arbitrary prices to a victim's cart via a single URL. Combined with absent CSRF tokens, this represents a complete loss of cart integrity exploitable via phishing. guestbook.php: simplifies stored XSS delivery via URL rather than form submission.
Remediation	Enforce HTTP POST method on all state-changing endpoints. In PHP: if ($_SERVER['REQUEST_METHOD'] !== 'POST') { http_response_code(405); exit; } Remove all GET-based parameter processing from cart.php, guestbook.php, and search.php.

VULN-16 — HTTP / HTML Charset Mismatch (Potential UTF-7 XSS Vector)

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-436 / WASC-15
Detected By	ZAP (Systemic — root, AJAX/index.php, cart.php, categories.php, index.php)
Description	The HTTP Content-Type response header declares UTF-8, while the HTML META content-type declarations specify iso-8859-2 (most pages) or iso-8859-1 (AJAX/index.php). This mismatch forces browsers into content-sniffing mode to resolve the conflict. On older or non-standard browsers, this can enable UTF-7 encoded XSS attacks that bypass standard XSS filters.
Impact	An attacker who can inject content near the beginning of a page may use UTF-7 encoding to execute scripts that evade standard filters. Compounds existing confirmed XSS vulnerabilities.
Remediation	Standardise on UTF-8 throughout: replace all iso-8859-x META declarations with charset='UTF-8'. Configure nginx to return Content-Type: text/html; charset=utf-8 for all HTML responses. Set default_charset = UTF-8 in php.ini.

VULN-17 — Information Disclosure — Directory Enumeration & Exposed Email Addresses

Severity	Informational
CVSS Rating	N/A
CVE / CWE	CWE-538 / WASC-13
Detected By	Nessus WebAPP Scan (Plugin 11032 — Web Server Directory Enumeration, Plugin 49705 — Harvested Email Addresses)
Description	Nessus successfully enumerated accessible server directories and harvested email addresses exposed in the application's HTML. Enumerated directories may include unprotected administrative or configuration paths. Exposed email addresses belong to users or administrators of the application.
Impact	Enumerated directories may reveal unprotected admin interfaces or backup files. Harvested email addresses enable targeted phishing and social engineering attacks against the application's users and administrators.
Remediation	Restrict access to all non-public directories via nginx deny all rules. Remove or obfuscate email addresses from publicly accessible HTML; use contact forms instead. Ensure robots.txt does not enumerate sensitive paths.

VULN-18 — Unrestricted HTTP Methods Enabled Per Directory

Severity	Informational
CVSS Rating	N/A

CVE / CWE	CWE-16
Detected By	Nessus WebAPP Scan (Plugin 43111 — HTTP Methods Allowed per directory)
Description	Nessus enumerated HTTP methods permitted on the server per directory. If directories permit dangerous methods such as PUT, DELETE, or TRACE beyond functional requirements, this represents an exploitable misconfiguration. The TRACE method in particular enables Cross-Site Tracing (XST) attacks when combined with XSS.
Impact	PUT: potential arbitrary file upload enabling web shell deployment. DELETE: arbitrary file deletion. TRACE: Cross-Site Tracing to steal cookies in conjunction with XSS. Actual impact depends on which methods are enabled on which directories.
Remediation	Restrict allowed HTTP methods in nginx per directory: limit_except GET POST { deny all; } Disable the TRACE method explicitly. Review each directory and remove all methods not required for application functionality.

8.5 Remediation Roadmap: VulnWeb Application

Priority	Timeframe	Action	Severity
P1	<24 hrs	Upgrade PHP 5.6.40 to PHP 8.3.x. Delete /secured/phpinfo.php. Enforce authentication on all /secured/ paths.	**Critical**
P2	<72 hrs	Replace all dynamic SQL with PDO prepared statements / MySQLi parameterised queries across every endpoint. Suppress raw database error messages.	**Critical**
P3	<1 week	Apply context-aware HTML output encoding on all user-supplied data. Prioritise guestbook.php (stored XSS). Set HttpOnly and Secure flags on session cookies.	**High**
P4	<1 week	Deploy TLS 1.2+ (Let's Encrypt). Enforce HTTPS-only. Implement HSTS. Apply Secure attribute to all cookies.	**High**
P5	<1 week	Sanitise XSLT inputs on showimage.php. Disable external entity resolution (libxml_disable_entity_loader(true)).	**High**
P6	<2 weeks	Enforce POST-only on cart.php, guestbook.php, search.php. Remove all GET-based state changes.	**Medium**
P7	<2 weeks	Implement per-session CSRF tokens on all state-changing forms. Validate server-side on every state-changing request.	**Medium**
P8	<1 month	Add CSP header, X-Frame-Options: DENY, and X-Content-Type-Options: nosniff to nginx configuration.	**Medium**
P9	<1 month	Suppress server version tokens (server_tokens off; expose_php=Off). Standardise all charset declarations to UTF-8.	**Low**
P10	<1 month	Remove wildcard entries from crossdomain.xml and clientaccesspolicy.xml. Add autocomplete='new-password' to password fields.	**Low**
P11	<2 months	Manual review: restrict HTTP methods per directory. Audit CGI parameters. Remove exposed emails. Restrict non-public directories.	**Low**

9. Overall Remediation Roadmap

The following roadmap consolidates prioritised actions across both targets. The Target column identifies which system each action applies to: Metasploitable 2 (10.0.2.4), VulnWeb App (testphp.vulnweb.com), or Both Targets where the action applies to either or all systems. Priority is determined by combined CVSS score, confirmed exploitability, business impact, and compliance implications.

Priority	Timeframe	Remediation Action	Target	Severity
P1	<24 hrs	ISOLATE 10.0.2.4 from all networks immediately. Treat as actively compromised. Block all traffic at firewall.	Metasploitable 2	**Critical**
P2	<24 hrs	Remove all four active backdoors immediately. (1) Kill Ingreslock on port 1524 (VULN-01). (2) Remove vsftpd 2.3.4; block port 6200 (VULN-02). (3) Remove UnrealIRCd; block ports 6667/6697 (VULN-03). (4) Remove ProFTPD 1.3.3c, replace with 1.3.8+; block ports 2121/tcp and 6200/tcp (VULN-57). All ProFTPD CVEs (VULN-57, VULN-73, VULN-74, VULN-90) are resolved by this single replacement. Kill all backdoor processes and remove all persistence mechanisms.	Metasploitable 2	**Critical**
P3	<24 hrs	Upgrade PHP 5.6.40 to PHP 8.3.x. Delete phpinfo.php. Suppress X-Powered-By version header.	VulnWeb App	**Critical**
P4	<72 hrs	Replace all dynamic SQL with PDO/MySQLi parameterised queries across all web endpoints.	Both Targets	**Critical**
P5	<72 hrs	Plan OS migration: rebuild 10.0.2.4 on Ubuntu 22.04/24.04 LTS from trusted base image. Resolves majority of CVEs.	Metasploitable 2	**Critical**
P6	<1 week	Patch Bash (Shellshock), PHP CGI (CVE-2012-1823), Tomcat (Ghostcat CVE-2020-1938). Disable DistCC.	Metasploitable 2	**Critical**
P7	<1 week	(1) Change or remove Tomcat Manager default credentials on port 8080 (VULN-43) AND on port 8180 (VULN-58 — separate Tomcat instance confirmed with tomcat:tomcat; apply RemoteAddrValve; shut down port 8180 if unused). (2) Disable anonymous FTP login (VULN-50). (3) Disable TFTP service or restrict to read-only chroot jail (VULN-44). (4) Delete or restrict /tikiwiki/tiki-install.php (VULN-60). (5) Delete or restrict /phpinfo.php; set expose_php=Off (VULN-63). (6) Add to httpd.conf: RangeOverlaps 0 to mitigate Apache Killer DoS (VULN-76). (7) Set X11Forwarding no in sshd_config — resolves VULN-94 and VULN-95 simultaneously.	Metasploitable 2	**Critical**
P8	<1 week	Deploy TLS 1.2+ / HTTPS. Enforce HTTP to HTTPS redirect. Implement HSTS. Apply Secure flag to all cookies.	VulnWeb App	**High**
P9	<1 week	Revoke all SSL/SSH keys generated on this host (Debian Weak RNG, CVE-2008-0166). Regenerate on fully patched system.	Metasploitable 2	**High**
P10	<1 week	Implement XSS output encoding on all user-supplied data. Prioritise guestbook.php (stored XSS).	Both Targets	**High**
P11	<1 week	Disable Telnet, rlogin, rsh, rexec. Set strong VNC password. Remove FTP weak and default accounts.	Metasploitable 2	**High**
P12	<1 week	Remove all .rhosts files and the /etc/hosts.equiv wildcard entry (VULN-48). Disable SMTP VRFY: set disable_vrfy_command=yes in Postfix (VULN-49).	Metasploitable 2	**High**
P13	<2 weeks	Sanitise XSLT inputs on showimage.php. Disable external entity resolution in XSLT processor.	VulnWeb App	**High**

P14	<2 weeks	Enforce POST-only on cart.php, guestbook.php, search.php. Implement per-session CSRF tokens on all forms.	VulnWeb App	**Medium**
P15	<1 month	(1) Remove Apache Log4j 1.x; migrate to Log4j 2.17.1+ (VULN-47). (2) Upgrade phpMyAdmin to current stable release 5.x: resolves VULN-46 (XSS), VULN-64 (setup.php RCE CVE-2009-1151), and VULN-82 (error.php XSS CVE-2010-4480) simultaneously. Delete /scripts/setup.php immediately if upgrade is delayed (VULN-64). (3) Enforce mandatory SMB signing in smb.conf (VULN-45).	Metasploitable 2	**High**
P16	<1 month	(1) Disable SSLv2/v3 on all services. Enforce TLS 1.2+. Remove RC4, EXPORT, and weak DH ciphers. (2) Replace all SSL/TLS certificates with RSA keys of minimum 2048 bits (VULN-98). (3) Add SSL_OP_NO_RENEGOTIATION to SSL context to prevent renegotiation DoS CVE-2011-1473 (VULN-79). (4) Deploy HTTPS across all web applications (DVWA, phpMyAdmin, TikiWiki, TWiki); enforce HTTPS-only with HSTS to prevent cleartext credential interception (VULN-83).	Metasploitable 2	**Medium**
P17	<1 month	Add CSP, X-Frame-Options: DENY, and X-Content-Type-Options: nosniff headers to all web responses.	Both Targets	**Medium**
P18	<1 month	Suppress server version tokens (server_tokens off, expose_php=Off). Standardise all charset declarations to UTF-8.	Both Targets	**Low**
P19	<2 months	(1) Restrict NFS exports to trusted IPs; restrict RPC/mountd access at firewall (VULN-68 mitigation). (2) Add to smb.conf immediately: wide links=no and unix extensions=no (mitigates VULN-89 symlink traversal). Disable SWAT or restrict to localhost (VULN-88). (3) Upgrade Samba to 4.13.17+ via OS migration to resolve all confirmed Samba RCE CVEs: VULN-21, VULN-59 (CVE-2021-44142), VULN-61, VULN-67, VULN-69, VULN-70, VULN-71, VULN-72. (4) Upgrade ISC BIND to 9.18.x+. Enable SMB signing. Disable HTTP TRACE. (5) Upgrade PostgreSQL to v10+; configure SCRAM-SHA-256 in pg_hba.conf (VULN-85).	Metasploitable 2	**Medium**
P20	<2 months	(1) Upgrade jQuery to 3.7.1+: resolves VULN-53 (CVE-2012-6708/CVE-2011-4969) plus VULN-97 (CVE-2019-11358 prototype pollution, CVE-2020-11022/23, CVE-2020-7656) simultaneously. (2) Disable SSL anonymous cipher suites across all TLS services (VULN-52). (3) Set HttpOnly and SameSite cookie flags in php.ini (VULN-55). (4) Disable directory listing (VULN-54). (5) Suppress internal IP disclosure from HTTP responses (VULN-56).	Metasploitable 2	**Medium**
P21	<2 months	(1) Address path traversal (VULN-23), open redirects (VULN-34), SSH weak algorithms (VULN-33); add HostKeyAlgorithms directive to sshd_config to also resolve weak host key algorithm (VULN-100). (2) Set LoginGraceTime 30 and MaxStartups 10:30:100 in sshd_config to prevent SSH connection slot exhaustion DoS (VULN-87). (3) Restrict dRuby (VULN-08). Disable X server remote access (VULN-40). Remove IRC daemon (VULN-41). Implement CSRF tokens application-wide (VULN-42). (4) Disable Java RMI Registry service or restrict port at firewall (VULN-78). (5) Restrict intentionally vulnerable apps (DVWA, Mutillidae, TWiki, phpMyAdmin) to isolated training network only; do not expose on any production interface (VULN-81). (6) Add session_regenerate_id(true) on login as interim PHP session fixation mitigation (VULN-91). (7) Suppress Unix timestamp disclosure from TWiki page output (VULN-99). (8) Incorporate NIST PQC standards (FIPS 203/204/205) into long-term architecture planning (VULN-101).	Metasploitable 2	**Low**

Appendix B: Raw Scan Reports

Appendix B1: Tenable Nessus — Metasploitable 2 (Basic Scan)

Tenable Nessus — Metasploitable 2 (Basic Scan).pdf

Appendix B2: Tenable Nessus — Metasploitable 2 (Credentialed Scan)

Tenable Nessus — Metasploitable 2 (Credentialed Scan).pdf

Appendix B3: Qualys VMDR — Metasploitable 2 (Basic Scan)

Qualys VMDR — Metasploitable 2 (Basic Scan).pdf

Appendix B4: Qualys VMDR — Metasploitable 2 (Credentialed Scan)

VMDR — Metasploitable 2 (Credentialed Scan).pdf

Appendix B5: Greenbone OpenVAS — Metasploitable 2

Greenbone OpenVAS — Metasploitable 2.pdf

Appendix B6: OWASP ZAP — Metasploitable 2

OWASP ZAP — Metasploitable 2.pdf

Appendix B7: Nikto — Metasploitable 2

Nikto — Metasploitable 2.html

Appendix B8: OWASP ZAP — VulnWeb Application

OWASP ZAP — VulnWeb Application.pdf (Command Line)

Appendix B9: Tenable Nessus — VulnWeb Application

Tenable Nessus — VulnWeb Application.pdf

Appendix B10: Greenbone OpenVAS — VulnWeb Application

Greenbone OpenVAS — VulnWeb Application.pdf

Appendix B11: Nikto — VulnWeb Application

Nikto — VulnWeb Application.html

CLASSIFICATION: CONFIDENTIAL – FOR AUTHORISED PERSONNEL ONLY
This report was produced from automated scan data. All findings should be validated through manual penetration testing prior to sign-off.
Severity ratings use CVSS v3.0 where available; CVSS v2.0 used where noted. | Report Reference: AFS-SOC-VULN-2026-001